



資安職能訓練- 資通安全概論 (第2天)

數位發展部資通安全署編製



第5單元

資通系統防護控制措施



第5單元學習目標



- 5-1 了解「存取控制」安全控制措施
- 5-2 了解「事件日誌與可歸責性」安全控制措施
- 5-3 了解「營運持續計畫」安全控制措施
- 5-4 了解「識別與鑑別」安全控制措施
- 5-5 了解「系統與服務獲得」安全控制措施
- 5-6 了解「系統與通訊保護」安全控制措施
- 5-7 了解「系統與資訊完整性」安全控制措施
- 5-8 了解「媒體控管及可攜式設備」安全控制措施



資通系統分級與防護基準

■ 資通安全責任等級機關應辦事項

附表10 資通系統防護基準

構面	1.存取控制	2.事件日誌與可歸責性	3.營運持續計畫	4.識別與鑑別	5.系統與服務獲得	6.系統與通訊保護	7.系統與資訊完整性
控制措施	帳號管理	記錄事件	資料備份	使用者之識別與鑑別	SSDLC需求階段	傳輸之機密性與完整性	漏洞修復
	最小權限	日誌紀錄內容	系統備援	身分驗證管理	SSDLC設計階段	資料儲存之安全	資通系統監控
	遠端存取	日誌儲存容量		鑑別資訊保護	SSDLC開發階段		軟體及資訊完整性
		日誌處理失效之回應			SSDLC測試階段		
		時戳及校時			SSDLC部署與維運階段		
		日誌資訊之保護			SSDLC委外階段		
					獲得程序		
					系統文件		



5-1 存取控制(1/6)

- **目的：**控制及限制對系統資源的存取權限，確保只有獲得授權的人員才能存取資料及資源，以降低資安風險。

措施內容	高	中	普
帳號管理	一、應依機關規定之情況及條件，使用資通系統。 二、監控資通系統帳號，如發現帳號違常使用時，回報管理者。 三、等級「中」之所有控制措施。	一、機關應定義各系統之間置時間或可使用期限與資通系統之使用情況及條件。 二、逾越機關所許可之間置時間或可使用期限時，系統應自動將使用者登出。 三、等級「普」之所有控制措施。	一、建立帳號管理機制，包含帳號之申請、建立、修改、啟用、停用及刪除之程序。 二、已逾期之臨時或緊急帳號應刪除或禁用。 三、資通系統閒置帳號應禁用。 四、定期審核資通系統帳號之申請、建立、修改、啟用、停用及刪除。
最小權限	採最小權限原則，僅允許使用者（或代表使用者行為之程序）依機關任務及業務功能，完成指派任務所需之授權存取。		



5-1 存取控制(2/6)

- **目的：**控制及限制對系統資源的存取權限，確保只有獲得授權的人員才能存取資料及資源，以降低資安風險。

措施內容	高	中	普
遠端存取	一、對於每一種允許之遠端存取類型，均應先取得授權，建立使用限制、組態需求、連線需求及文件化。 二、使用者之權限檢查作業應於伺服器端完成。 三、應監控遠端存取機關內部網段或資通系統後臺之連線。 四、應採用加密機制。 五、遠端存取之來源應為機關已預先定義及管理之存取控制點。		



5-1 存取控制(3/6)

■ 帳號管理：

- **建立帳號管理機制(高中普)：**包含帳號之申請、建立、修改、啟用、停用及刪除之程序
- **臨時與緊急帳號管理(高中普)：**已逾期之臨時或緊急帳號應刪除或禁用
- **閒置帳號管理(高中普)：**資通系統閒置帳號應禁用
- **帳號定期審核(高中普)：**定期審核資通系統帳號之申請、建立、修改、啟用、停用及刪除
- **系統操作限制(高中)：**機關應定義各系統之閒置時間或可使用期限與資通系統之使用情況及條件
- **帳號自動登出(高中)：**逾越機關所許可之閒置時間或可使用期限時，系統應自動將使用者登出
- **系統使用規定(高)：**應依機關規定之情況及條件，使用資通系統
- **系統帳號監控(高)：**監控資通系統帳號，如發現帳號違常使用時回報管理者



5-1 存取控制(4/6)

■ 最小權限：

採最小權限原則(高中普)：僅允許使用者(或代表使用者行為之程序)依機關任務及業務功能，完成指派任務所需之授權存取

■ 遠端存取：

- **遠端存取授權(高中普)：**對於每一種允許之遠端存取類型，均應先取得授權，建立使用限制、組態需求、連線需求及文件化
- **權限檢查實作(高中普)：**使用者之權限檢查作業應於伺服器端完成
- **連線監控(高中普)：**應監控遠端存取機關內部網段或資通系統後台之連線
- **連線加密(高中普)：**應採用加密機制
- **來源管制(高中普)：**遠端存取之來源應為機關已預先定義及管理之存取控制點



5-1 存取控制(5/6)

■ 存取控制-授權原則

➤ 業務僅知原則

- 只提供執行業務上所需知道的資訊

➤ 最小權限原則

- 權限開放時採用最小權限原則

➤ 職務區隔

- 避免某些衝突或監督工作職務由同一個人來進行

➤ 特殊權限管理

- 對於系統管理者帳號及相關安全組態設定權限，應採特別的控管方式，並詳細記錄特權人員的存取行為



5-1 存取控制(6/6)



■ 存取控制-類型

- **實體類控制(Physical Controls)**
 - 門、窗及圍牆
 - 鎖
 - 警衛
- **技術類控制(Technical Controls)**
 - 通行碼鑑別
 - 加解密技術
 - 生物特徵識別技術
 - 防火牆系統
- **管理類控制(Administrative Controls)**
 - 政策與程序
 - 安全認知訓練
 - 風險管理



5-2 事件日誌與可歸責性(1/6)

■ **目的：**記錄及保存資通系統及網路活動的日誌，以追蹤系統及使用者的操作

措施內容	高	中	普
記錄事件	- 應定期審查機關所保留資通系統產生之日誌。 - 等級「普」之所有控制措施。		- 訂定日誌之記錄時間週期及留存政策，並保留日誌至少六個月。 - 確保資通系統有記錄特定事件之功能，並決定應記錄之特定資通系統事件。 - 應記錄資通系統管理者帳號所執行之各項功能。
日誌記錄內容	資通系統產生之日誌應包含事件類型、發生時間、發生位置及任何與事件相關之使用者身分識別等資訊，採用單一日誌機制，確保輸出格式之一致性，並應依資通安全政策及法規要求納入其他相關資訊。		
日誌儲存容量	依據日誌儲存需求，配置所需之儲存容量。		



5-2 事件日誌與可歸責性(2/6)

措施內容	高	中	普
日誌處理失效之回應	1. 機關規定需要即時通報之日誌處理失效事件發生時，資通系統應於機關規定之時效內，對特定人員提出警告。 2. 等級「中」及「普」之所有控制措施。	資通系統於日誌處理失效時，應採取適當之行動。	
時戳及校時	1. 資通系統應使用系統內部時鐘產生日誌所需時戳，並可以對應到世界協調時間（UTC）或格林威治標準時間（GMT）。 2. 系統內部時鐘應定期與基準時間源進行同步。		
日誌資訊之保護	1. 定期備份日誌至原系統外之其他實體系統 2. 等級「中」之所有控制措施。	1. 應運用雜湊或其他適當方式之完整性確保機制 2. 等級「普」之所有控制措施。	對日誌之存取管理，僅限於有權限之使用者。



5-2 事件日誌與可歸責性(3/6)

■ 記錄事件：

- 日誌留存(高中普)：訂定日誌之記錄時間週期及留存政策，並保留日誌至少6個月
 - － 保存項目：作業系統日誌(OS event log)、網站日誌(web log)、應用程式日誌(AP log)、登入日誌(logon log)
- 事件記錄(高中普)：確保資通系統有記錄特定事件之功能，並決定應記錄之特定資通系統事件
 - － 於特定系統事件發生時應觸發日誌記錄行為
- 管理者行為記錄(高中普)：應記錄資通系統管理者帳號所執行之各項功能
 - － 資通系統應記錄管理者行為，有助於追查資安事件或發現濫權行為
- 日誌審查(高中)：應定期審查機關所保留資通系統產生之日誌



5-2 事件日誌與可歸責性(4/6)

■ 日誌紀錄內容：

- **內容與格式(高中普)：**資通系統產生之日誌應包含事件類型、發生時間、發生位置及任何與事件相關之使用者身分識別等資訊，採用單一日誌機制，確保輸出格式之一致性，並應依資通安全政策及法規要求納入其他相關資訊

■ 日誌儲存容量：

容量配置(高中普)：依據日誌儲存需求，配置所需之儲存容量

■ 日誌處理失效之回應：

- **回應行動(高中普)：**資通系統於日誌處理失效時，應採取適當之行動
- **即時通報(高)：**機關規定需要即時通報之日誌處理失效事件發生時，資通系統應於機關規定之時效內，對特定人員提出警告



5-2 事件日誌與可歸責性(5/6)

■ 時戳及校時：

- **時戳(高中普)：**資通系統應使用系統內部時鐘產生日誌所需時戳，並可以對應到世界協調時間(UTC)或格林威治標準時間(GMT)
- **校時(高中普)：**系統內部時鐘應定期與基準時間源進行同步

■ 日誌資訊之保護：

- **存取控制(高中普)：**對日誌之存取管理，僅限於有權限之使用者
- **完整性(高中)：**應運用雜湊或其他適當方式之完整性確保機制
- **定期備份(高)：**定期備份日誌至原系統外之其他實體系統

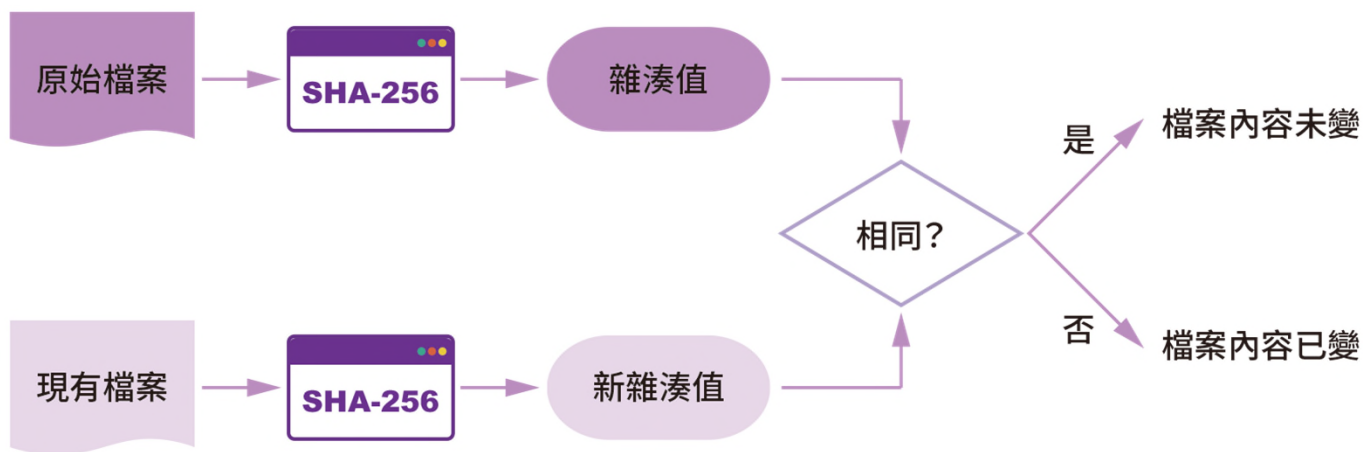


5-2 事件日誌與可歸責性(6/6)

■ 什麼是雜湊？

雜湊是一種從任何資料中建立「數位指紋」的方法

- 若依據同一個雜湊函式(例如SHA-256)計算得到了兩個不相同的雜湊值，則這兩個原始輸入也是不相同的



- 雜湊常用來驗證資料完整性
- 雜湊因具有單向性，無法從雜湊值計算回推原始訊息，故也可用來儲存使用者密碼



5-3 營運持續計畫(1/12)

■ **目的：**確保在突發事件或災難情況下，機關的關鍵業務能夠持續運作

措施內容	高	中	普
資料備份	1. 應將備份還原，作為營運持續計畫演練之一部分。 2. 應建立資料異地備份機制。 3. 等級「中」之有控制措施。	1. 應定期測試備份資料，以驗證備份媒體之可靠性及資訊之完整性。 2. 等級「普」之所有控制措施。	1. 訂定資料可容忍損失之時間要求。 2. 執行資料備份。
系統備援	1. 應將備援啟動作為營運持續計畫演練之一部分。 2. 等級「中」之所有控制措施。	1. 應定期測試原服務中斷時，於最大可容忍中斷時間內，由備援設備或其他方式取代並提供服務。 2. 等級「普」之所有控制措施。	訂定資通系統從中斷後至重新恢復服務之最大可容忍中斷時間要求。

RPO：資料可容忍損失之時間要求；MTPD：資通系統從中斷後至重新恢復服務之最大可容忍中斷時間要求。



5-3 營運持續計畫(2/12)

■ 資料備份：

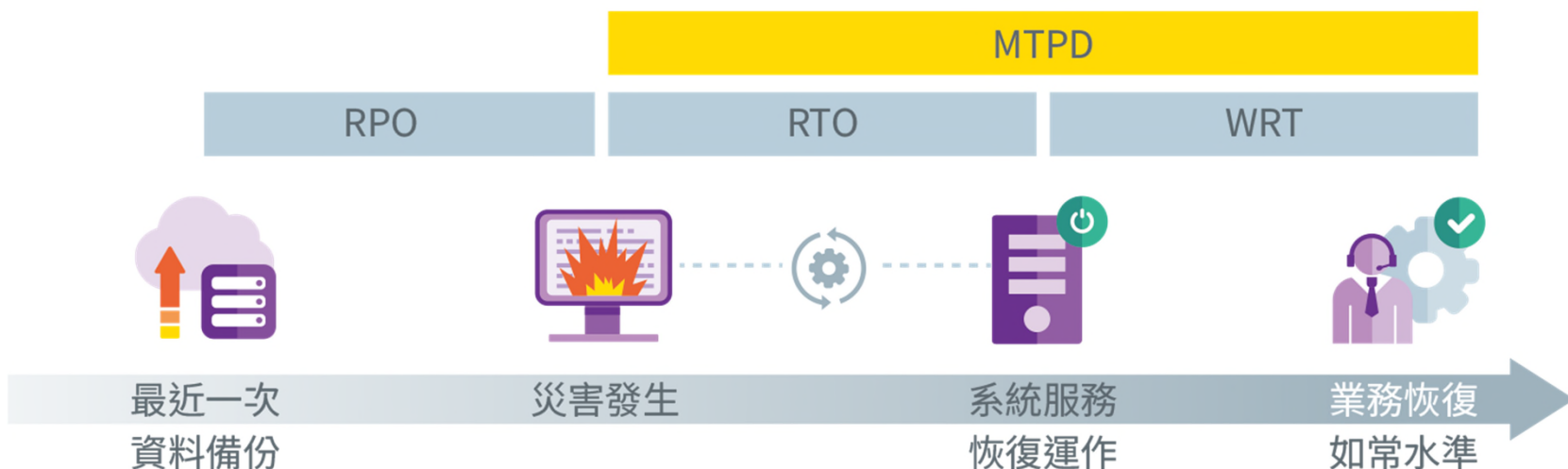
- 復原點目標(Recovery Point Objective, RPO) (高中普)：訂定資料可容忍損失之時間要求。
- 資料備份(高中普)：執行資料備份
- 測試備份媒體(高中)：應定期測試備份資料，以驗證備份媒體之可靠性及資訊之完整性
- 還原測試(高)：應將備份還原，作為營運持續計畫演練之一部分
 - － 營運持續計畫(BCP)應定期演練，在災害復原過程中應使用備份資料驗證備份機制是否正確可靠
- 異地備份(高)：應建立資料異地備份機制。
 - － 機關亦可參考「我國電腦機房異地備援機制參考指引」中，異地備份/備援機制提及之主機房與異地備援機房之距離應距離30公里以上，做為參考依據



5-3 營運持續計畫(3/12)

■ 系統備援：

- 最大可容忍中斷時間(Maximum Tolerable Period of Disruption, MTPD) (高中普)：訂定資通系統從中斷後至重新恢復服務之最大可容忍中斷時間要求
- 備援設備(高中)：應定期測試原服務中斷時，於最大可容忍中斷時間內，由備援設備或其他方式取代並提供服務
- 備援演練(高)：應將備援啟動作為營運持續計畫演練之一部分





5-3 營運持續計畫(4/12)

■ 備份備援常見相關術語

名詞	英文	英文縮寫	意義
營運衝擊分析	Business Impact Analysis	BIA	用來了解當災害發生後的嚴重程度，以及所需之處理時間
復原點目標	Recovery Point Objective	RPO	資料可容忍損失之時間
復原時間目標	Recovery Time Objective	RTO	資通系統從中斷後至重新恢復服務之可容忍時間
工作復原時間	Work Recovery Time	WRT	讓核心業務回到災害發生前的服務水準所需之時間，其中工作如復原資料、驗證系統及資料正確性等
最大可容忍中斷時間	Maximum Tolerable Period of Disruption	MTPD	為核心業務與其所需資源評估資通系統最大可容忍中斷之時間



5-3 營運持續計畫(5/12)

■ 資料備份

- **目的：**為對抗資料毀損的威脅與抵抗勒索攻擊，以保護資料的可用性
 - 個人使用者可為自己的重要資料進行備份
 - 機關應有系統人員對內部重要系統與檔案統一進行備份
 - 機關應建立備份資料復原程序
 - 備份媒介可為光碟、行動碟、其他電腦、磁帶與大型儲存系統



5-3 營運持續計畫(6/12)

■ 資料備份

➤ 備份方式

- 完整備份、差異備份及增量備份

➤ 備份模式

- 異地與本地兩種

➤ 備份週期

- 每日、每週、每月及每季

➤ 回復測試

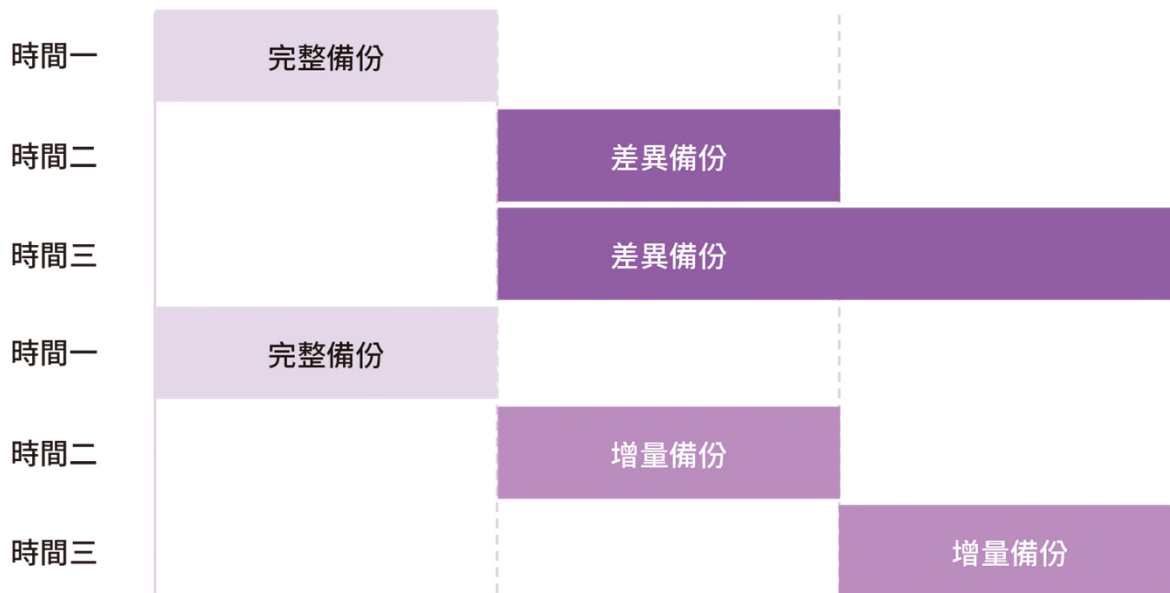
- 應確認備份的資料回復之後可正常運作



5-3 營運持續計畫(7/12)

■ 資料備份-方式(1/3)

- **完整備份**：將要備份的檔案完整地複製一份保存在備份儲存媒體中
- **差異備份**：備份上次完整備份後，內容有變更或新增的檔案



- **增量備份**：備份上次完整備份或增量備份後，內容有變更或新增的檔案

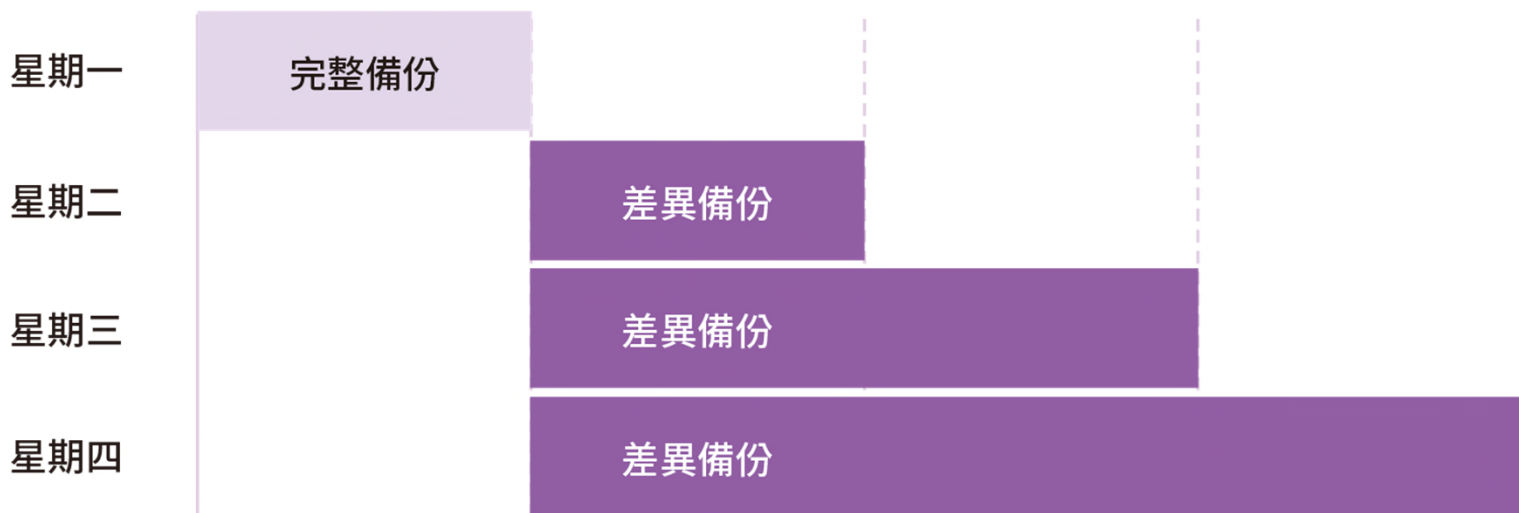


5-3 營運持續計畫(8/12)

■ 資料備份-方式(2/3)

➤ 完整備份與差異備份

星期一進行完整備份，星期二至星期五進行差異備份，假設星期五時資料毀損，需要復原星期一的完整備份與星期四的差異備份



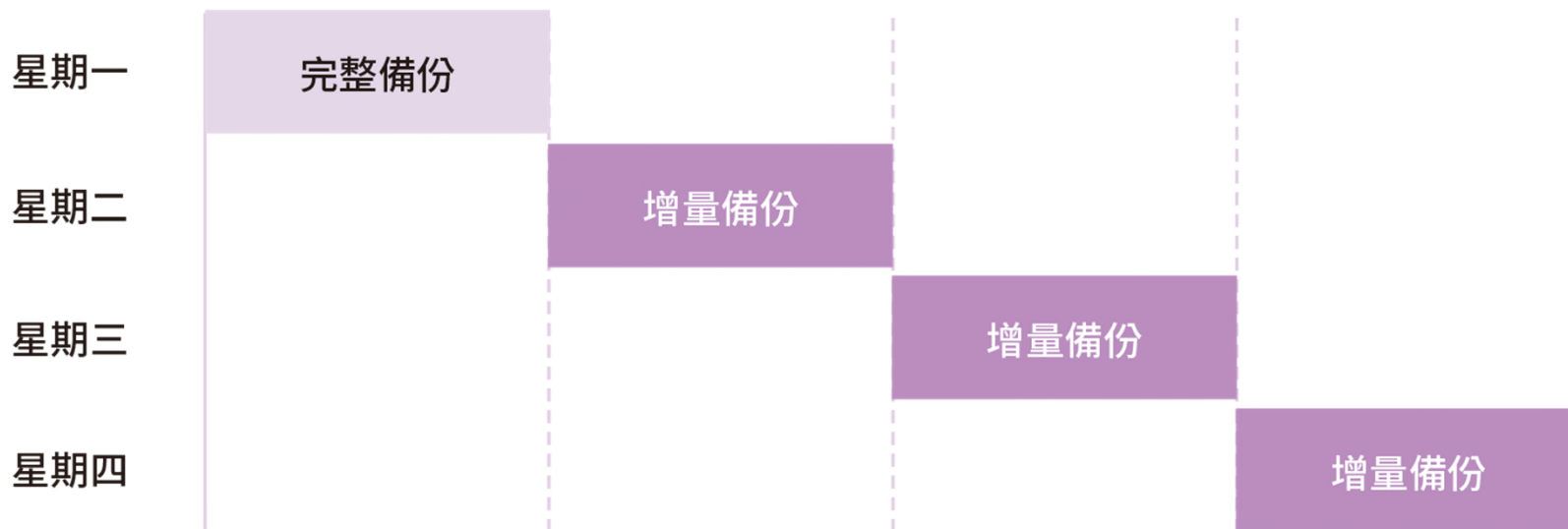


5-3 營運持續計畫(9/12)

■ 資料備份-方式(3/3)

➤ 完整備份與增量備份

- 星期一進行完整備份，星期二至星期五進行增量備份，假設星期五時資料毀損，需要復原星期一的完整備份與從星期二至星期四的所有增量備份





5-3 營運持續計畫(10/12)

■ 資料備份-模式(1/2)

- **本地備份**：將檔案儲存至備份媒體後，保存於原地點
 - 如果使用的備份媒體存在於同一部電腦的硬碟中，雖然備份的程序最簡便，但是當電腦硬碟故障時，備份資料亦同時受損，則備份的效能無法發揮
 - 如備份媒體使用光碟片，但保存於同一機房中，雖然可以避免前例硬碟故障的問題，但若機房發生火警時，則備份資料亦可能同時毀損





5-3 營運持續計畫(11/12)

■ 資料備份-模式(2/2)

- **異地備份**：將檔案儲存至備份媒體後，保存於不同地點
 - － 此模式的備份程序與成本較高，但可避免前例的安全問題
 - － 應考慮地震帶、颱風、土石流等因素，規避同時受災可能性
 - － 異地備份地點相距愈遠，其防護效果愈佳
 - － 例如：當地震發生時，相距10公里內的距離可能遭受同樣程度的毀損，但相隔100公里的距離則其毀損程度可能就大不相同



5-3 營運持續計畫(12/12)



■ 資料備份-注意事項

- 備份的範圍應該事先評估，避免該備份的沒有備份
- 備份媒體的問題
 - 資訊設備變化甚快，應定期檢驗備份媒體是否仍有合適的存取設備
- 檔案格式的問題
 - 備份檔案的格式，可能因年代久遠而找不到相容的工具可以開啟。應定期檢查備份檔案，確認仍有合適的應用軟體或工具可開啟
- 機關應提供足夠之備份設施，確保發生災害後可復原
- 機關應進行備份資料的回復演練，以確保備份資料可以正確的回復
- 測試備份資料回復，應先於專屬媒體上執行，以防止復原過程失敗，造成資料毀損，相關計畫應列入營運持續計畫中辦理



5-4 識別與鑑別(1/22)

■ 目的：確保只有經過授權的使用者才能存取系統，保障資通系統的安全

措施內容	高	中	普
使用者之識別與鑑別	- 對資通系統之存取採取多因子鑑別技術。 - 等級「中」及「普」之所有控制措施。	資通系統應識別及鑑別使用者，並禁止使用者使用共用帳號。	
身分驗證管理	- 身分驗證機制應防範自動化程式之登入或密碼更換嘗試。 - 密碼重設機制對使用者重新身分確認後，發送一次性及具有時效性符記。 - 等級「普」之所有控制措施。		- 使用預設密碼初次登入系統時，應於登入後立即變更。 - 身分驗證相關資訊不以明文傳輸。 - 具備帳戶鎖定機制，帳號登入進行身分驗證失敗達五次後，至少十五分鐘內不允許該帳號繼續嘗試登入或使用機關自建之失敗驗證機制。 - 使用密碼進行驗證時，應強制最低密碼複雜度；依機關密碼效期規定變更密碼。 - 密碼變更時，至少不可以與前三次使用過之密碼相同。 - 第四點及第五點所定措施，對外部使用者，機關得自行規範辦理。



5-4 識別與鑑別(2/22)

措施內容	高	中	普
鑑別資訊保護	1. 資通系統如以密碼進行鑑別時，該密碼應經雜湊或其他適當方式處理後儲存。 2. 等級「普」之所有控制措施。		資通系統應遮蔽鑑別過程中之資訊。



5-4 識別與鑑別(3/22)

■ 使用者之識別與鑑別

- **識別及鑑別使用者(高中普)**：資通系統應識別及鑑別使用者，並禁止使用者使用共用帳號
- **多因子鑑別技術(高)**：對資通系統之存取採取多因子鑑別技術

■ 身分驗證管理

- **變更預設密碼(高中普)**：使用預設密碼初次登入系統時，應於登入後要求立即變更
- **禁止明文傳輸(高中普)**：身分驗證相關資訊不以明文傳輸
- 身分驗證相關資訊，如密碼，傳輸時應加密或編碼保護
- **帳戶鎖定(高中普)**：具備帳戶鎖定機制，帳號登入進行身分驗證失敗 達5次後，至少15分鐘內不允許該帳號繼續嘗試登入或使用機關自建之失敗驗證機制
- **密碼複雜度與效期(高中普)**：使用密碼進行驗證時，應強制最低密碼複雜度；依機關密碼效期規定變更密碼



5-4 識別與鑑別(4/22)

■ 身分驗證管理

- **管制相同密碼(高中普)**：密碼變更時，至少不可以與前3次使用過之密碼相同
- **規範外部使用者 (高中普)**：第四點及第五點所定措施，對外部使用者，機關得自行規範辦理
- **防範自動化程式(高中)**：身分驗證機制應防範自動化程式之登入或密碼更換嘗試
- **密碼重設機制(高中)**：密碼重設機制對使用者重新身分確認後，發送1次性及具有時效性符記



5-4 識別與鑑別(5/22)

■ 鑑別資訊保護

- **遮蔽密碼(高中普)**：資通系統應遮蔽鑑別過程中之資訊
- **密碼儲存安全(高中)**：資通系統如以密碼進行鑑別時，該密碼應加密或經雜湊或其他適當方式處理後儲存



5-4 識別與鑑別(6/22)

■ 使用者識別符(Identifier)

➤ 使用者識別符(名稱、代碼或帳號)的要求

- 必須唯一，以確保人員的可歸責性，不能有多人共用帳號的情形
- 與使用者真實身分連結，在資通系統中代表使用者身分
- 發展命名方式並遵循(例如：Firstname_Lastname)
- 不代表其在機關中的角色或職位

➤ 使用者識別符的管理

- 機關必須有識別符申請、異動及刪除的管理程序，可與人事異動之管理流程結合
- 識別符的申請、異動及刪除必須獲得授權主管的核准
- 應定期盤查使用者識別符，以發現已離職或非授權識別符
- 識別符刪除後應暫停一段時間新增相同名稱的識別符
- 一段時間沒使用的識別符應停用



5-4 識別與鑑別(7/22)

■ 使用者鑑別符(Authenticator)

➤ 鑑別符

- 用來驗證使用者身分的佐證資訊或物品，可能是通行碼、晶片卡、數位憑證、動態通行碼產生器或指紋等

➤ 使用者鑑別符管理

- 確保鑑別符具備足夠的強度
- 為初始鑑別符的配發、遺失鑑別符及註銷鑑別符建立與實作管理程序
- 在資通系統安裝時變更預設的鑑別符
- 建立鑑別符最長壽命的限制，以及重新使用的情況
- 定期變更鑑別符
- 保護鑑別符內容，以免被非授權洩露與修改
- 需要使用者擔負與設備實作特定的防護措施，以保護鑑別符安全



5-4 識別與鑑別(8/22)

■ 識別符及鑑別符之可歸責性

- 使所有存取行為都可歸責到使用者真實身分的機制，至少應滿足下列條件
 - 首先必須要具備唯一識別符可代表使用者真實身分
 - 足夠強固的使用者鑑別技術，能防止身分鑑別機制被破解
 - 系統所有存取路徑被強制控管
 - 所有存取行為不論成功或失敗都被詳實記錄
 - 系統存取紀錄的時戳代表存取順序
 - 系統存取紀錄應被妥善保護，任何人均無法修改或刪除



5-4 識別與鑑別(9/22)

■ 身分鑑別技術-鑑別因素

- 基於所知(Something You Know)
 - － 通行碼
- 基於所有(Something You Have)
 - － 晶片卡
- 與生具備(Something You Are)
 - － 指紋





5-4 識別與鑑別(10/22)

■ 身分鑑別技術-強固鑑別技術

- 同時採用兩種鑑別因素的鑑別技術，即可稱為強固鑑別技術
- 例如：
 - 晶片卡(Have)配合PIN碼(Know)
 - 指紋(Are)配合通行碼(Know)
 - 晶片卡(Have)配合指紋(Are)



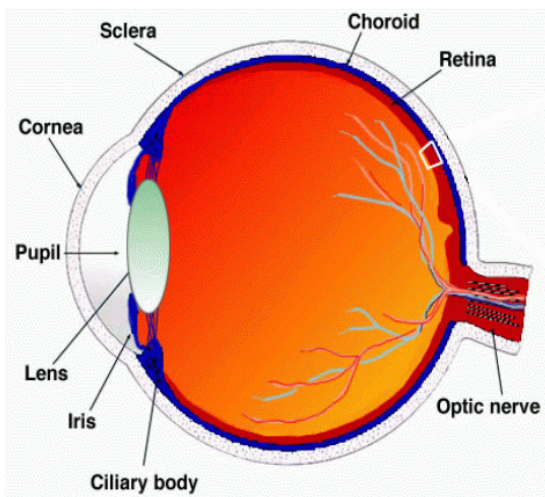


5-4 識別與鑑別(11/22)

■ 身分鑑別技術-生物特徵鑑別

➤ 生物特徵鑑別

- 採用人類具備的屬性進行識別與鑑別
- 最昂貴、最複雜、也最能識別人員身分的鑑別技術
- 但人類社會中對這種技術的接受性較低(隱私、侵入性及傳染病等)

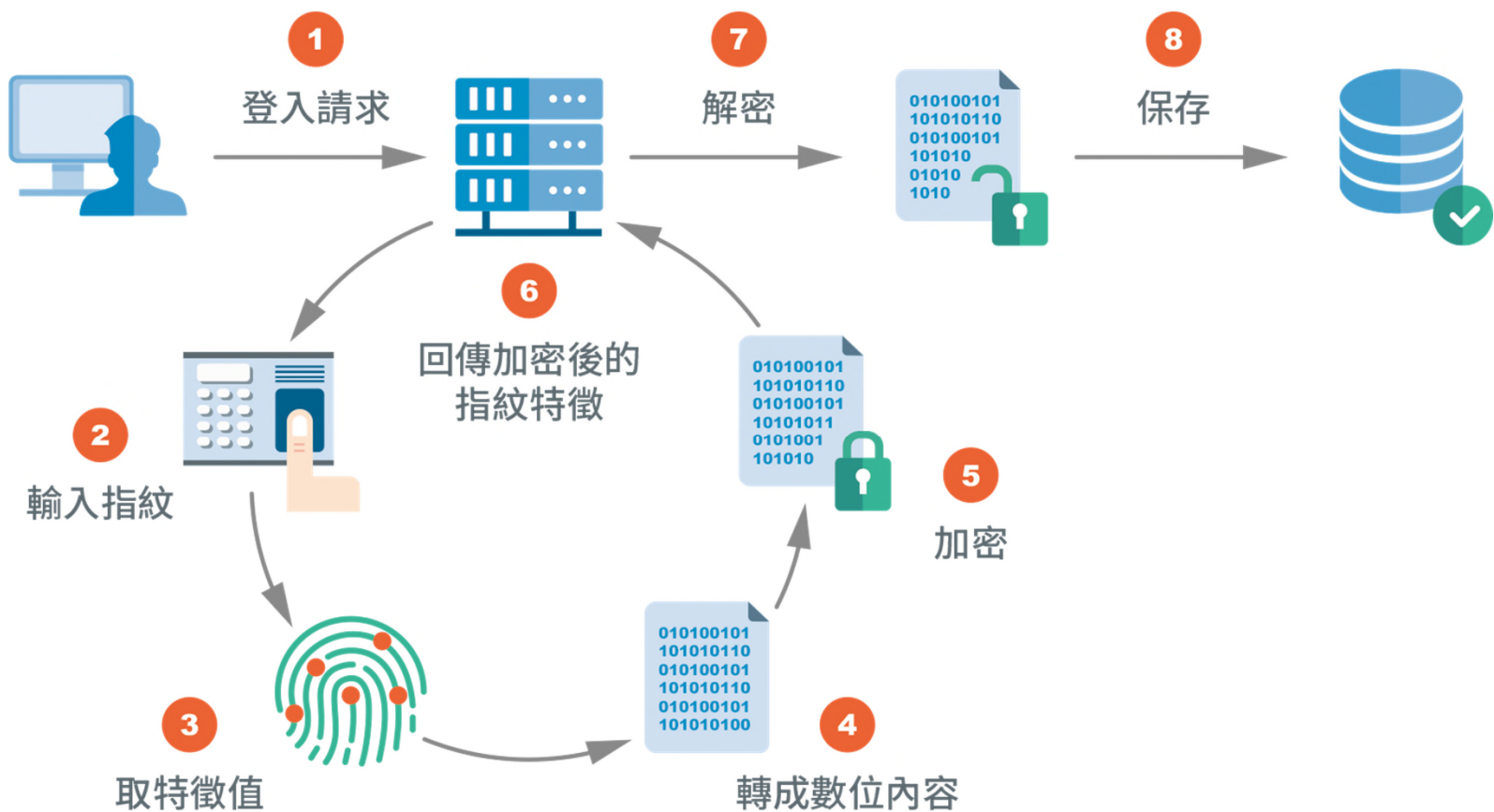




5-4 識別與鑑別(12/22)

■ 身分鑑別技術-生物特徵登錄步驟

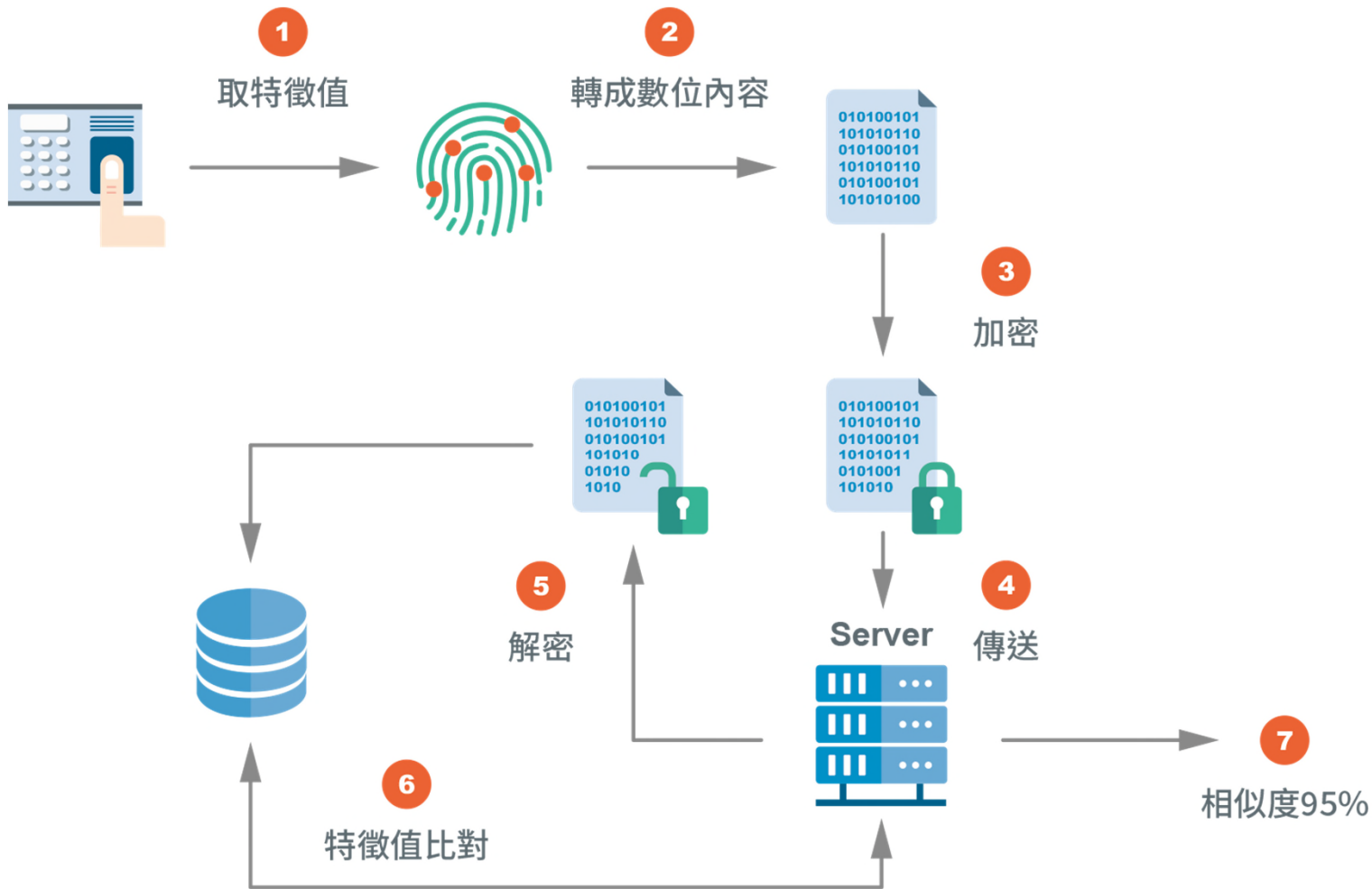
➤ 生物特徵登錄步驟(以指紋為例)





5-4 識別與鑑別(13/22)

■ 身分鑑別技術-生物特徵鑑別步驟



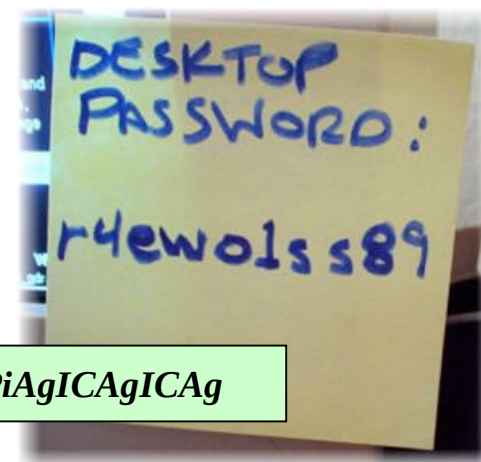


5-4 識別與鑑別(14/22)

■ 身分鑑別技術-通行碼身分鑑別技術

- 目前使用「最廣泛」也「最簡便」的身分鑑別技術
- 亦是最不安全的身分鑑別技術
 - 使用者選用了「懶人通行碼」
 - 共用通行碼
 - 將通行碼貼在螢幕上
 - 從不更改通行碼
 - 輸入通行碼時被別人看到按下的通行碼
- 這組通行碼安全嗎？

`RAqr2lSKjTqPOnVSKkvbDIpEit+7jqpnfCvq/gtfu2cSKxTa7XoUMKPiAgICAgICAg`



- 針對通行碼的攻擊
 - 字典猜測法
 - 暴力式通行碼猜測
 - 通行碼監聽



5-4 識別與鑑別(15/22)



■ 身分鑑別技術-通行碼身分鑑別技術

➤ 避免通行碼被破解的防護措施

- 系統強制要求長度至少8碼
 - ✓ 包含文字、數字及符號、包含大小寫
 - ✓ 在字典中查不到
- 系統強制要求使用者定期更換通行碼
- 由系統判斷通行碼不重覆使用
- 可限制通行碼容許登入失敗的次數
- 簽入成功或失敗都應被記錄
- 使用通行碼檢測工具尋找脆弱性通行碼
- 通行碼不以明碼方式儲存(雜湊)
- 通行碼不以明碼方式在網路上傳送
- 加強保護集中存放通行碼雜湊值的伺服器



5-4 識別與鑑別(16/22)

■ 身分鑑別技術-一次性通行碼身分鑑別技術(1/3)

- 一次性通行碼(One-time Password)或稱動態通行碼的特質
 - 由隨身攜帶的符記(Token)或軟體自動產生簽入用通行碼
 - 簽入時每次產生的通行碼只能使用一次
 - 可防止通行碼被竊聽而偽冒簽入的問題
 - 可防止通行碼猜測攻擊

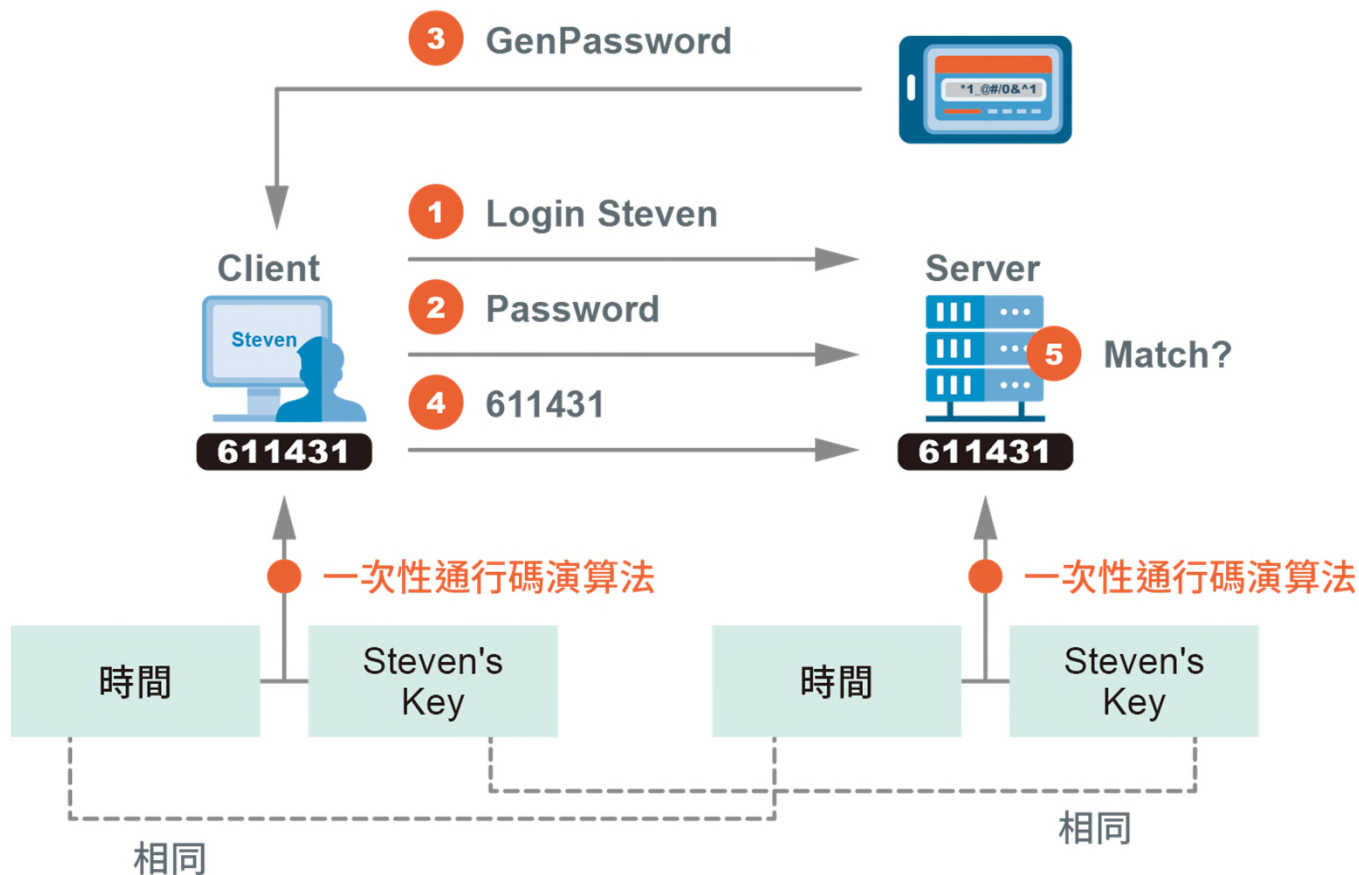




5-4 識別與鑑別(17/22)

■ 身分鑑別技術-同步式一次性通行碼技術(2/3)

➢ 一次性通行碼產生符記與鑑別伺服器有同步機制

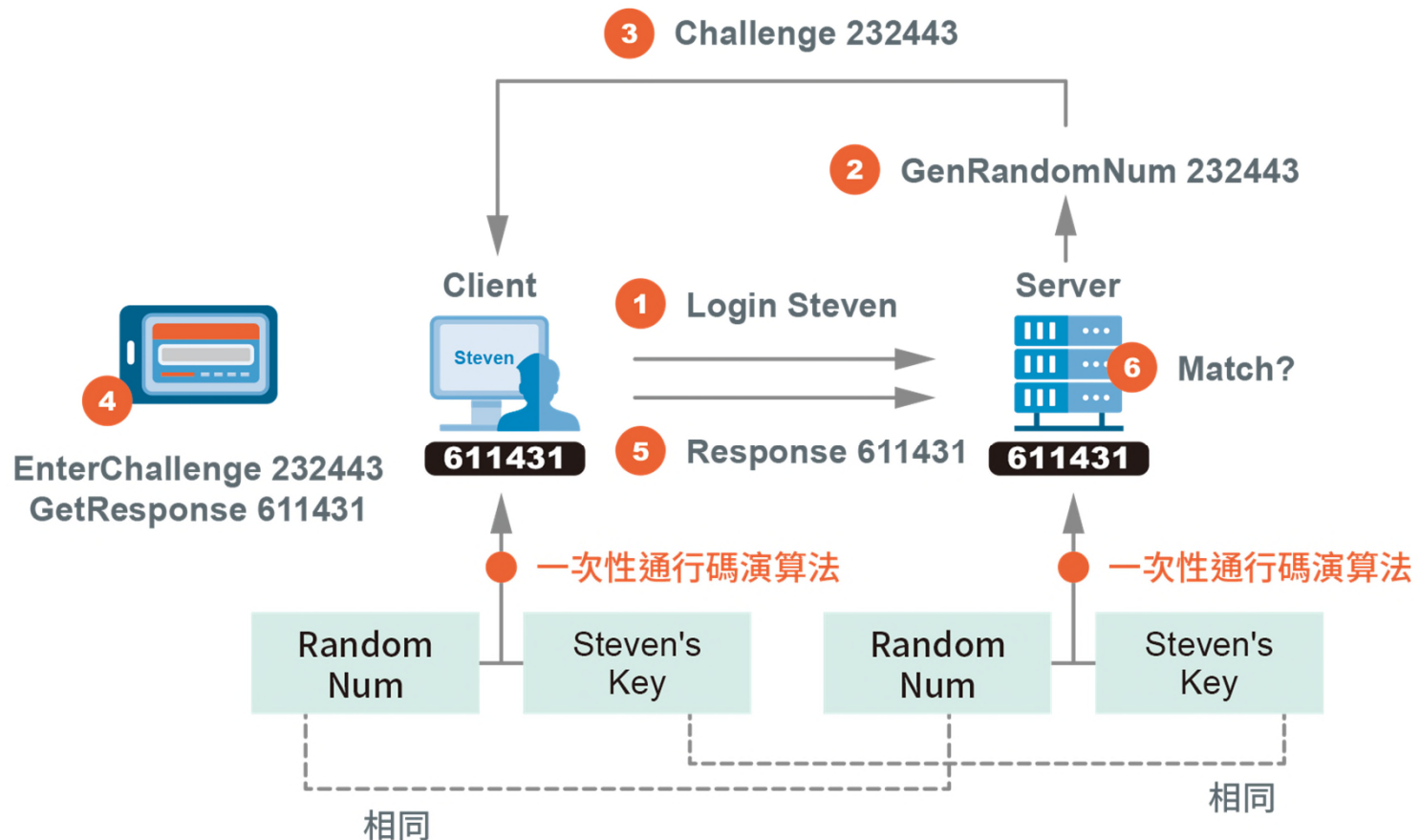




5-4 識別與鑑別(18/22)

■ 身分鑑別技術-非同步式一次性通行碼技術(3/3)

- 一次性通行碼產生符記與鑑別伺服器沒有同步機制



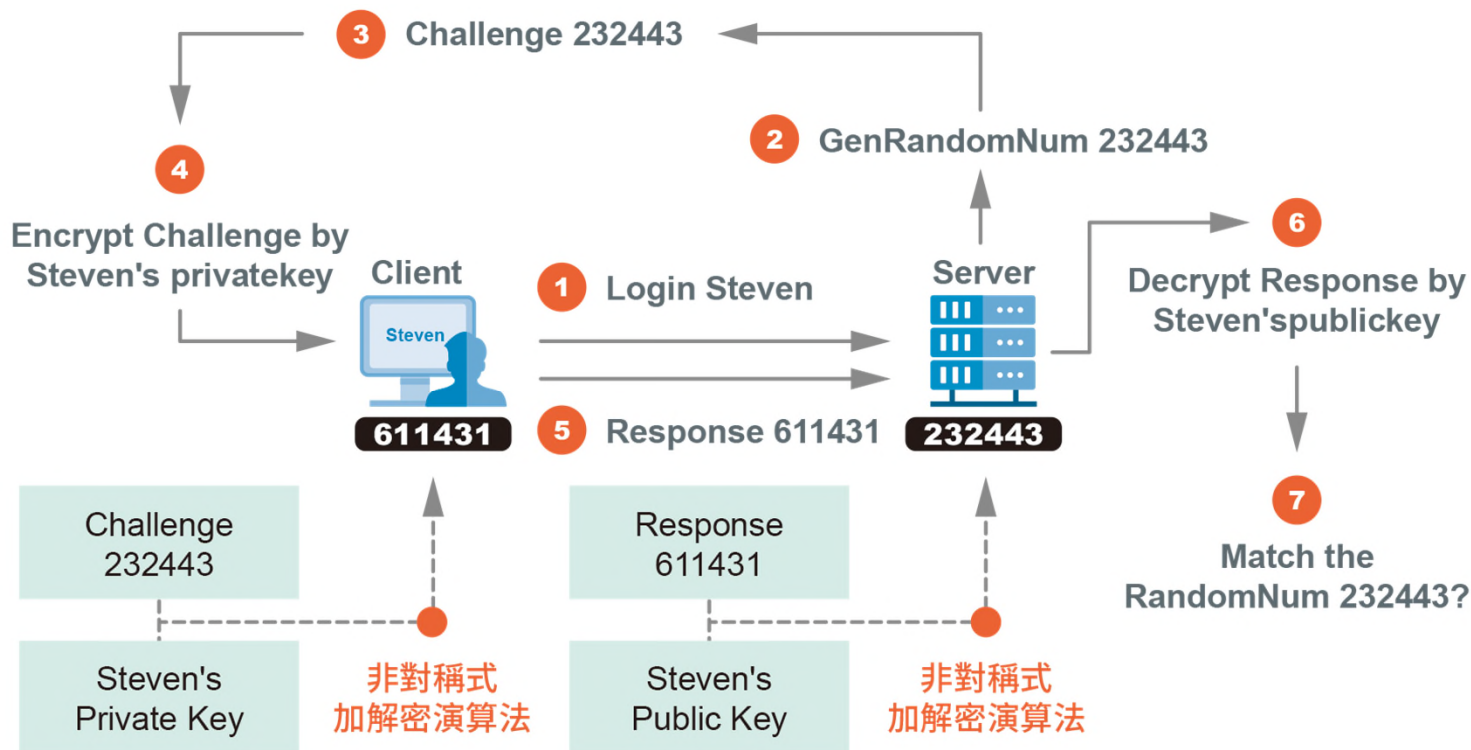


5-4 識別與鑑別(19/22)

■ 身分鑑別技術-詰問與回應身分鑑別技術

➤ 採用加密機制 完成身分鑑別

- 運用非對稱式加解密演算法
- 雙方不必分享共同的金鑰
- 不必輸入任何通行碼或回應訊息即可完成鑑別





5-4 識別與鑑別(20/22)

■ 符記(Token)

- 適合隨身攜帶的卡片或感應器，用來實作「基於所有(Something you have)」身分鑑別技術
- 通常可分為下列幾種類型
 - 記憶卡
 - 智慧卡
- 依其感應或資料傳輸的方式又可分為
 - 接觸式
 - 非接觸式
- 符記的外型
 - 卡片式(例如：信用卡)
 - 隨身型計算機
 - 鑰匙環裝飾品的USB符記





5-4 識別與鑑別(21/22)

■ 記憶卡

- 沒有微處理器，甚至沒有積體電路，只有磁條
 - 例如：信用卡與舊式金融卡
- 記憶空間中只存放身分鑑別時所需的資訊，例如：私密金鑰與帳號
- 使用者至少需要輸入PIN碼
- 將帳號、PIN碼及記憶卡中的鑑別資訊傳送到後端鑑別伺服器，經解密或雜湊運算後比對即可完成身分鑑別





5-4 識別與鑑別(22/22)

■ 智慧卡

➤ 智慧卡(Smart Card)的特質

- 具備微處理器與積體電路
- 可記憶也可運算
- 具備防拆解與竄改的保護機制
- 必須輸入PIN或通行碼啟動智慧卡功能

➤ 智慧卡可運用在

- 存放生物識別特徵碼
- 挑戰與回應(Challenge/Response)的私密金鑰儲存與加密運算
- 存放持有人的購物紀錄與就醫紀錄





5-5 系統與服務獲得(1/8)

- 目的：確保在系統各個階段（需求、設計、開發、測試、部署與維運）充分考慮安全性需求

措施內容	高	中	普
系統發展生命週期 需求階段	針對系統安全需求(含機密性、可用性、完整性)進行確認		
系統發展生命週期 設計階段	1. 根據系統功能與要求，識別可能影響系統之威脅，進行風險分析及評估。 2. 將風險評估結果回饋需求階段之檢核項目，並提出安全需求修正。		無要求
系統發展生命週期 開發階段	1. 執行「源碼掃描」安全檢測。 2. 系統應具備發生嚴重錯誤時之通知機制。 3. 等級「中」及「普」之所有控制措施	1. 應針對安全需求實作必要控制措施。 2. 應注意避免軟體常見漏洞及實作必要控制措施。 3. 發生錯誤時，使用者頁面僅顯示簡短錯誤訊息及代碼，不包含詳細之錯誤訊息。	



5-5 系統與服務獲得(2/8)

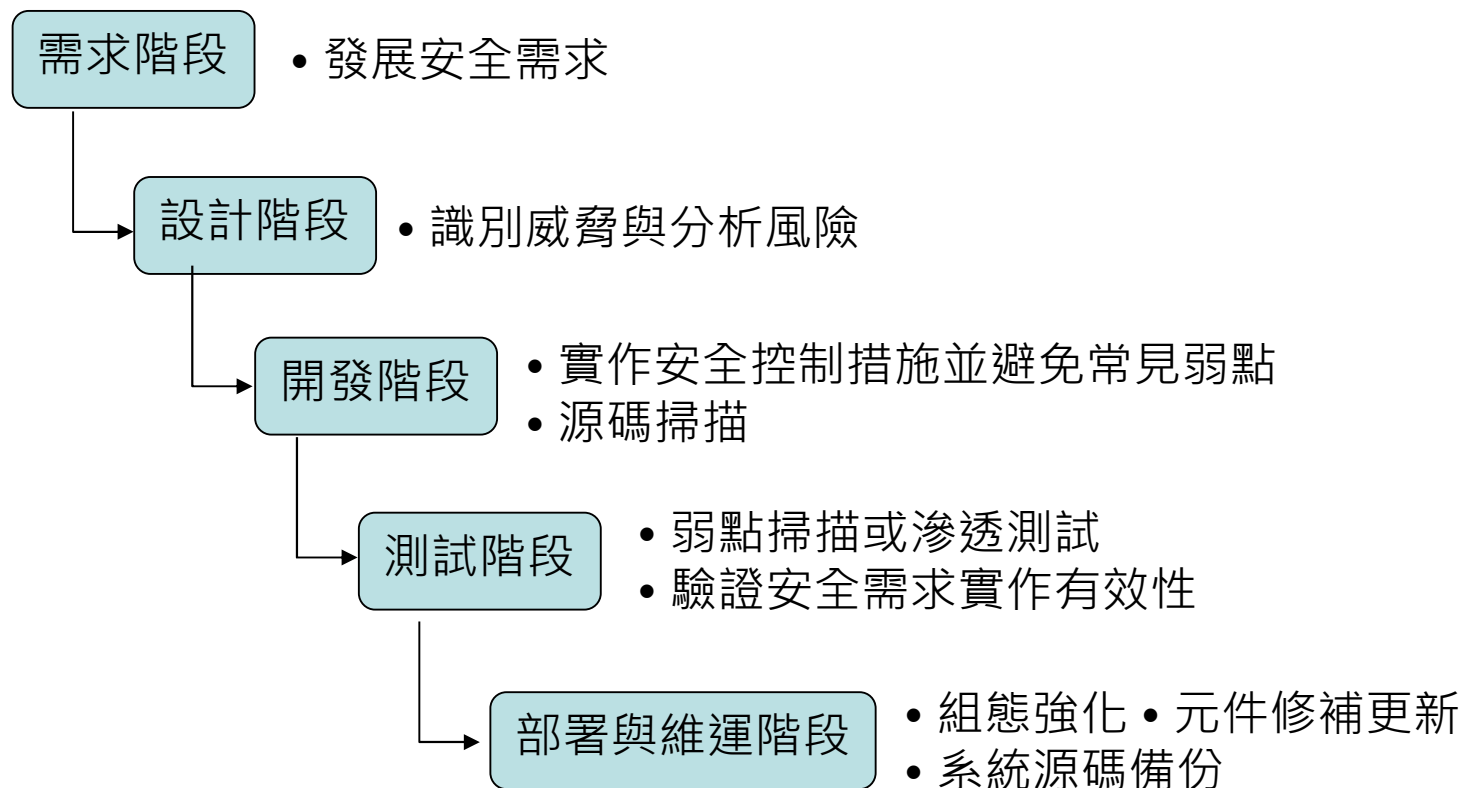
措施內容	高	中	普
系統發展生命週期 測試階段	1. 執行「滲透測試」安全檢測。 2. 等級「中」及「普」之所有控制措施。	執行「弱點掃描」安全檢測。	
系統發展生命週期 部署與維運階段	1. 於系統發展生命週期之維運階段，應執行版本控制與變更管理。 2. 等級「普」之所有控制措施。	1. 於部署環境中應針對相關資通安全威脅，進行更新與修補。 2. 識別並關閉不必要服務及埠口。 3. 資通系統不使用預設密碼。 4. 執行系統源碼備份。	
系統發展生命週期 委外階段	資通系統開發如委外辦理，應將系統發展生命週期各階段依等級將安全需求（含機密性、可用性、完整性）納入委外契約。		
獲得程序	1. 開發、測試及正式作業環境應為區隔。 2. 等級「普」之所有控制措施。	識別資通系統使用之第三方軟體、服務、函式庫或其他元件。	
系統文件	應儲存與管理系統發展生命週期之相關文件。		



5-5 系統與服務獲得(3/8)

■ 安全系統發展生命週期(SSDLC)

- SSDLC強調於專案各階段及早加入安全思維，以 打造具備安全體質的資通系統





5-5 系統與服務獲得(4/8)

■ 需求階段-確認安全需求(高中普)

- 針對系統安全需求(含機密性、可用性、完整性)進行確認
 - 系統安全需求可能來自於法規或業界標準要求、內部資安政策或業務需求等來源，應仔細確認後再開始進行系統設計與實作等活動

■ 設計階段-威脅識別與風險評估(高中)

- 根據系統功能與要求，識別可能影響系統之威脅，進行風險分析及評估
 - 風險是指威脅利用其相對應脆弱性造成組織或政府機關資訊資產受到衝擊的可能性
 - 識別資通系統面臨之資安威脅，並進一步分析各種威脅之風險

■ 設計階段-安全需求修正(高中)

- 將風險評估結果回饋需求階段之檢核項目，並提出安全需求修正
 - 當完成上述威脅識別與風險評估活動，可能從中發現當初未考慮到之威脅，此時應思考對應之安全控制措施，並進行安全需求之修正



5-5 系統與服務獲得(5/8)

■ 開發階段-安全需求實作(高中普)

- 應針對安全需求實作必要控制措施
 - － 資通系統應訂定安全需求項目，包含機密性、完整性及 可用性 等相關要求，並應確實實作

■ 開發階段-避免常見漏洞(高中普)

- 應注意避免軟體常見漏洞及實作必要控制措施
 - － 稽核驗證宜確認機關相關管理規範及安全強化作為

■ 開發階段-處理錯誤訊息(高中普)

- 發生錯誤時，使用者頁面僅顯示簡短錯誤訊息與 代碼，不包含詳細之錯誤訊息
 - － 系統宜客製化錯誤頁面，隱藏錯誤程式碼位置與內容等機敏訊息

■ 開發階段-源碼掃描(高)

- 執行「源碼掃描」安全檢測
 - － 機關宜選用具安全檢測能力之工具，以發現源碼安全弱點



5-5 系統與服務獲得(6/8)



■ 開發階段-嚴重錯誤通知機制(高)

- 系統應具備發生嚴重錯誤時之通知機制
 - 系統應具備可靠且有效之系統錯誤通知機制，避免無人發覺與處理

■ 測試階段-弱點掃描(高中普)

- 執行「弱點掃描」安全檢測
 - 弱點掃描包含系統(主機)弱點掃描與網站弱點掃描
 - 機關宜選用具安全檢測能力之自動化檢測工具，對目標進行掃描，常見如連接埠掃描、作業系統識別、版本掃描、常見弱點檢測等

■ 測試階段-滲透測試(高)

- 執行「滲透測試」安全檢測
 - 一般由資安專家手動進行，效果取決於人員經驗與技術

■ 部署與維運階段-系統更新與修補(高中普)

- 於部署環境中應針對相關資通安全威脅，進行更新與修補，識別並關閉不必要服務及埠口
 - 如作業系統安全性更新
 - 識別系統服務與埠口(Port)：原則關閉，有需要才開放



5-5 系統與服務獲得(7/8)

■ 部署與維運階段-禁用預設密碼及執行系統源碼備份(高中普)

- 資通系統不使用預設密碼
 - 相關軟體(例如套裝軟體、資料庫、Web伺服器等)應 避免使用預設密碼，建議於系統正式上線前停用或完成 密碼變更
- 執行系統源碼備份
 - 防範意外損毀：確保遭駭或災難時可快速重建。
 - 避免廠商綁架：防範委外解約或倒閉導致系統無法維護。
 - 保留鑑識依據：發生資安事件時，提供乾淨源碼追查漏洞。

■ 部署與維運階段-版本控制與變更管理(高中)

- 於系統發展生命週期之維運階段，應執行版本控制與變更管理
 - 版本控制目的在需要時可取回特定版本，機關應依 ISMS或其他相關規定進行系統變更



5-5 系統與服務獲得(8/8)

■ 委外階段-委外安全需求(高中普)

- 資通系統開發如委外辦理，應將系統發展生命週期各階段依等級將安全需求(含機密性、可用性、完整性)納入委外契約
 - － 將系統安全需求明確納入委外契約，並據以驗收

■ 獲得程序-識別第三方元件(高中普)

- 識別資通系統使用之第三方軟體、服務、函式庫或其他元件
 - － 盤點並識別資通系統使用哪些第三方的軟體、服務、函式庫或其他元件

■ 獲得程序-作業環境區隔(高中)

- 開發、測試及正式作業環境應為區隔
 - － 開發環境、測試環境及正式作業環境應實作必要之存取控制，以保護正式作業環境之系統與資料

■ 系統文件-文件儲存與管理(高中普)

- 應儲存與管理系統發展生命週期之相關文件
 - － 系統發展生命週期之相關文件應以書面或電子化形式進行文件保存，並被納入管理程序



5-6 系統與通訊保護(1/17)

■ 目的：確保資通系統及資料傳輸的機密性、完整性及可用性

措施內容	高	中	普
傳輸之機密性與完整性	- 資通系統應採用加密機制，以防止未授權之資訊揭露或偵測資訊之變更。但傳輸過程中有替代之實體保護措施者，不在此限。 - 使用公開、國際機構驗證且未遭破解之演算法。 - 加密金鑰或憑證應定期更換。 - 伺服器端之金鑰保管應訂定管理規範及實施應有之安全防護措施。	無要求	無要求
資料儲存之安全	資通系統重要組態設定檔案及其他具保護需求之資訊應加密或以其他適當方式儲存。	無要求	無要求



5-6 系統與通訊保護(2/17)



■ 傳輸之機密性與完整性-傳輸加密(高)

- 資通系統應採用加密機制，以防止未授權之資訊揭露或偵測資訊之變更。但傳輸過程中有替代之實體保護措施者，不在此限
- 資通系統應實作傳輸加密機制，如HTTPS 1.2/1.3、SSH、SFTP及VPN等加密傳輸協定，或其他足以確保資料傳輸過程機密性與完整性之安全控制措施

■ 傳輸之機密性與完整性-演算法(高)

- 主機或網站弱點使用公開、國際機構驗證且未遭破解之演算法
- 掃描通常可檢測出是否已啟用不安全的傳輸協定



5-6 系統與通訊保護(3/17)



■ 傳輸之機密性與完整性-金鑰憑證更換(高)

- 加密金鑰或憑證應定期更換
- 避免使用萬年憑證而增加被破解的風險，已過期憑證應儘速更換
- 對外服務站台應使用合法憑證中心核發之伺服器憑證

■ 傳輸之機密性與完整性-金鑰保管(高)

- 伺服器端之金鑰保管應訂定管理規範及實施應有之安全防護措施
- 強化存取控制，加密金鑰與加密資料應分開存放，以確保金鑰的機密性、完整性及可用性

■ 資料儲存之安全-組態與資料保護(高)

- 資通系統重要組態設定檔案及其他具保護需求之資訊應加密或以其他適當方式儲存



5-6 系統與通訊保護(4/17)

■ 加密與簽章技術

➤ 主要用途

- 確保資訊的「機密性」、「完整性」、「鑑別性」及「不可否認性」

➤ 經常運用在各種資通系統的安全防護機制中

- 資料通訊的安全(VPN、SSL或SSH等)
- 資料儲存的安全(硬碟加密、檔案加密或資料庫加密等)
- 身分鑑別的安全(數位憑證身分鑑別)
- 資料完整性與不可否認的安全(電子簽章)

➤ 加密技術

- 對稱式加密演算法(秘密金鑰)
- 非對稱式加解密演算法(公開金鑰)

➤ 簽章技術

- 雜湊函數
- 數位簽章



5-6 系統與通訊保護(5/17)



■ 加密技術強度

- 加密技術強度指的是密碼破解所需花費的時間與資源
- 加密技術強度通常牽涉到下列的因素
 - 演算法強度
 - 金鑰保護機制
 - 金鑰的長度
 - 亂數產生器的不可預測性
- 密碼系統的安全性不在演算法的保密
 - 專屬的演算法不見得安全，經得起挑戰的演算法才是被證明為安全的
- 目前加解密被成功攻擊的原因大部分屬人為因素
 - 不正確的實作加密機制
 - 不安全金鑰保密機制



5-6 系統與通訊保護(6/17)

■ 加密技術強度的相關法令

➤ 電子票證應用安全強度準則

- 明確要求金融服務業，對於電子票證相關服務必須採用的加密或簽章之演算法強度
- 電子票證：指以電子、磁力或光學形式儲存金錢價值，並含有資料儲存或計算功能之晶片、卡片、憑證或其他形式之債據，作為多用途支付使用之工具



5-6 系統與通訊保護(7/17)

■ 對稱式加密演算法(1/4)

- 對稱式密碼學(Symmetric Cryptography)又稱作「秘密金鑰密碼學(SecretKey Cryptography)」
- 也就是加密與解密用的是「同一把金鑰」
- 這把金鑰雙方都必須好好保護，才能確保密文的安全強度，因此叫「秘密金鑰」





5-6 系統與通訊保護(8/17)



■ 對稱式加密演算法(2/4)

➤ DES

- 美國密碼演算法標準
- 有效金鑰長度56位元

➤ Triple-DES

- DES演算法重複使用
- 有效金鑰長度112/168位元

➤ RC2,RC4,RC5,RC6

- 美國RSA公司開發之演算法、金鑰長度為可變長度

➤ AES

- 比利時JoanDaemen與VincentRijmen所開發
- 於2000年AES計畫中，獲選為新一代密碼演算法標準



5-6 系統與通訊保護(9/17)

■ 對稱式加密演算法(3/4)

➤ 優點

- 加解密速度較非對稱式加解密演算法快
- 如果金鑰長度夠長，將難以被破解

➤ 缺點

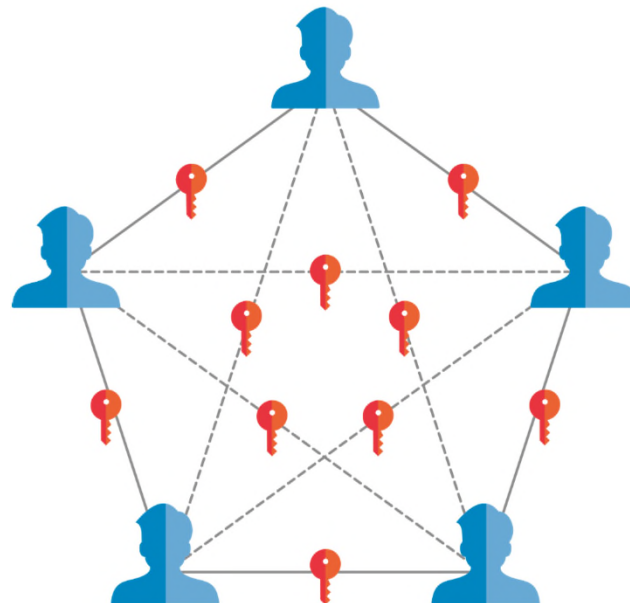
- 當加密對象多時，金鑰的保護與交換變得很麻煩
- 將金鑰傳送至加密對象，需要額外的安全機制
- 只提供機密性保護功能，無法提供不可否認性功能



5-6 系統與通訊保護(10/17)

■ 對稱式加密演算法(4/4)

- 當加密對象人數愈多時，就代表私密金鑰的個數也愈多
 - N個使用者需要 $N(N-1)/2$ 把金鑰
 - 3個使用者需要3把金鑰
 - 10個使用者需要45把金鑰
 - 1,000個使用者需要499,500把金鑰





5-6 系統與通訊保護(11/17)

■ 非對稱式加解密演算法(2/4)

➤ 非對稱式加解密演算法的金鑰

- 由公開金鑰加密只能用私密金鑰解密
- 由私密金鑰加密只能用公開金鑰解密

流程一：



流程二：





5-6 系統與通訊保護(12/17)



■ 非對稱式加解密演算法(3/4)

➤ RSA

- 使用最廣泛，也是最有名的演算法
- 安全性導因於解因數分解的困難度
- 具有資料加密與數位簽章功能

➤ ElGamal

- 安全性導因於解離散對數的困難度
- 具有資料加密與數位簽章功能



5-6 系統與通訊保護(13/17)



■ 非對稱式加解密演算法(4/4)

➤ 優點

- 金鑰管理較容易，每個人兩把金鑰，1,000個人也只要2,000把金鑰
- 公開金鑰可以任意公開傳送，不需額外的保護機制

➤ 缺點

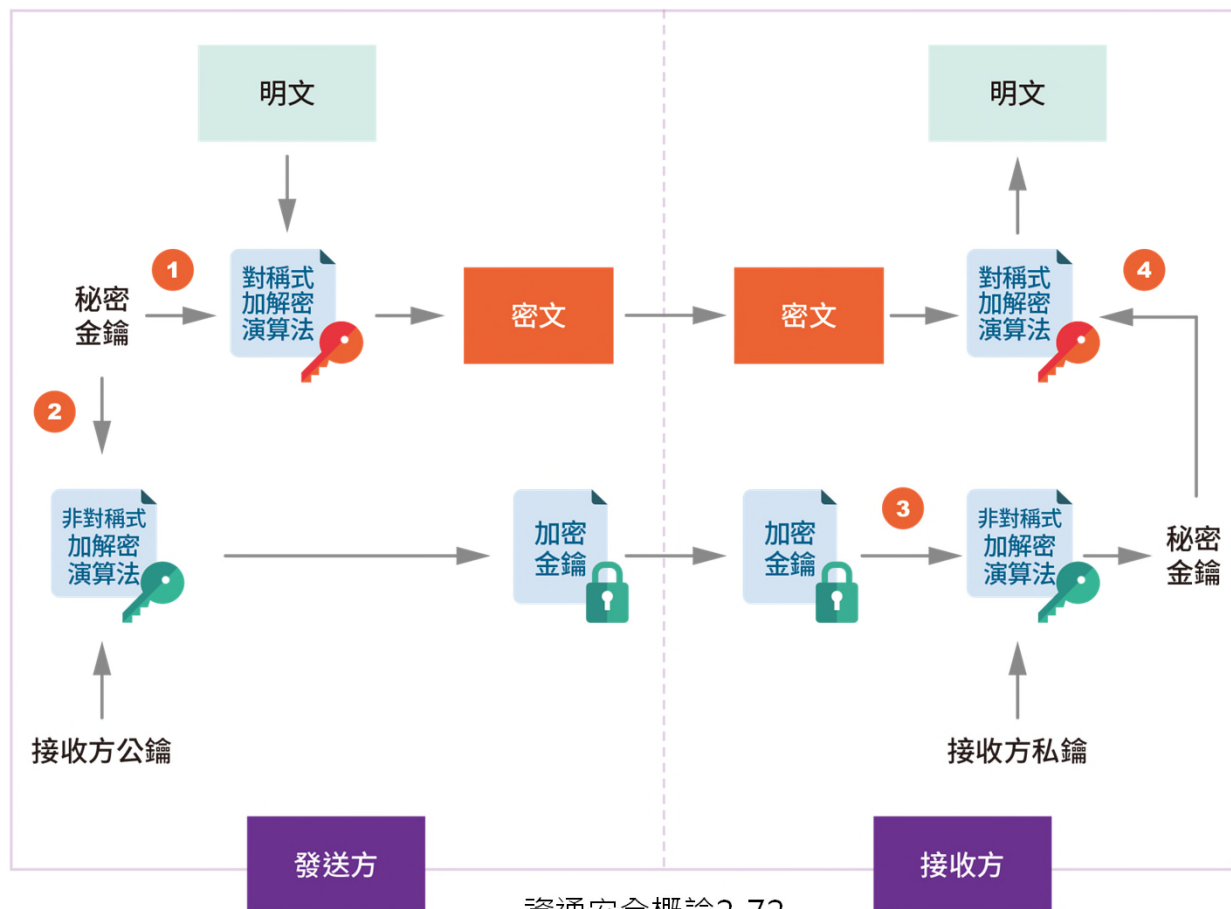
- 加解密速度比對稱式加解密演算法慢



5-6 系統與通訊保護(14/17)

■ 數位信封

- 結合對稱式與非對稱式加解密演算法的優點
- 如同將資料裝入信封，只有接收者才能拆開信封



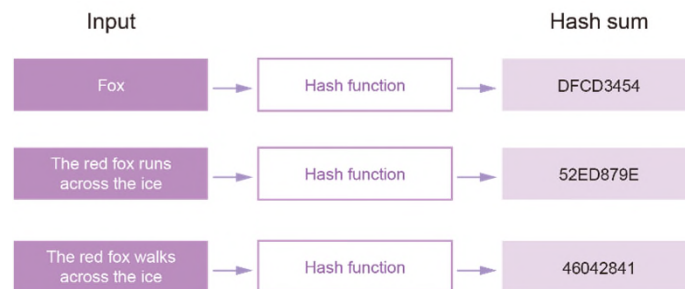


5-6 系統與通訊保護(15/17)



■ 雜湊函數之特性與安全性分析

- 根據同一函式，將任何長度的資料轉成固定長度的**訊息摘要**(MessageDigest)，也稱為「**數位指紋**」(DigitalFingerprint)
- 原始訊息不變則雜湊值相同(且唯一)
- 無法從雜湊值回推原始訊息(單向)，不具有可逆性
- 如果兩個雜湊值是不相同的(根據同一雜湊函式)，那麼這兩個雜湊值的原始輸入也是不相同的
- 演算法
 - MD5,SHA-256,SHA-512,SHA3-512





5-6 系統與通訊保護(16/17)



■ 數位簽章-目的

➤ 目的

- 證明電子檔案為簽章者所傳送
- 資料被竄改時可以發現

➤ 甲方要把電子檔案簽章後傳送給乙方

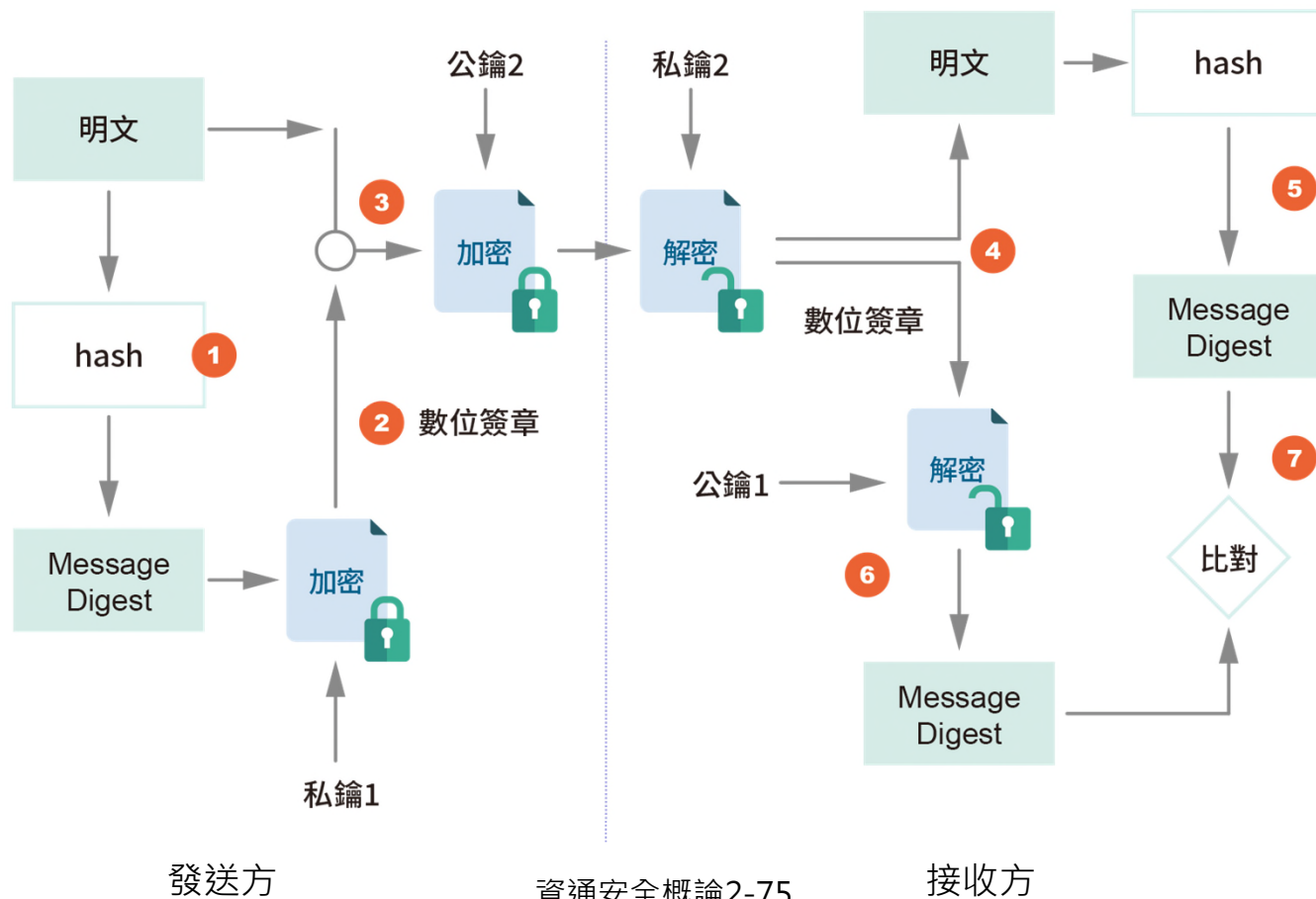
- 甲方用自己的私密金鑰對電子檔案作簽章
- 電子檔案與簽章一起傳送給乙方
- 乙方用甲方的公開金鑰驗證簽章，可驗證出電子檔案沒有被竄改，的確是由甲方所傳送



5-6 系統與通訊保護(17/17)

■ 數位簽章-流程

- 數位簽章技術同時提供了訊息的「完整性」、「鑑別性」及「不可否認性」





5-7 系統與資訊完整性(1/4)

■ **目的：**確保資通系統及其儲存及處理的資訊不被非法篡改或破壞

措施內容	高	中	普
漏洞修復	1. 定期確認資通系統相關漏洞修復之狀態。 2. 等級「普」之所有控制措施。		系統之漏洞修復應測試有效性及潛在影響，並定期更新。
資通系統監控	1. 資通系統應採用自動化工具監控進出之通信流量，並於發現不尋常或未授權之活動時，針對該事件進行分析。 2. 等級「中」之所有控制措施。	1. 監控資通系統，以偵測攻擊與未授權之連線，並識別資通系統之未授權使用。 2. 等級「普」之所有控制措施。	發現資通系統有被入侵跡象時，應通報機關特定人員。
軟體及資訊完整性	1. 應定期執行軟體與資訊完整性檢查。 2. 等級「中」之所有控制措施。	1. 使用完整性驗證工具，以偵測未授權變更特定軟體及資訊。 2. 發現違反完整性時，資通系統應實施機關指定之安全保護措施。 3. 等級「普」之所有控制措施。	使用者輸入資料合法性檢查應置放於應用系統伺服器端。



5-7 系統與資訊完整性(2/4)

■ 漏洞修復-修復漏洞及定期更新(高中普)

- 系統之漏洞修復應測試有效性及潛在影響，並定期更新
- 定期進行軟體更新，先於測試用主機上完成更新可行性評估並通過測試後，始於正式環境進行更新

■ 漏洞修復-確認漏洞修復狀態(高中)

- 機關宜注意相關之安全漏洞訊息(如透過CVE相關訊息網站、廠商安全通告等)
- 由弱點掃描與滲透測試等安全檢測活動所檢出之系統漏洞應設法修復，並定期追蹤修復進度，或配合定期之安全檢測作業確認複測
- 稽核驗證宜檢視機關弱點修補追蹤管理機制



5-7 系統與資訊完整性(3/4)

■ 資通系統監控-監控通報(高中普)

- 發現資通系統有被入侵跡象時，應通報機關特定人員

■ 資通系統監控-監控資通系統連線(高中)

- 監控資通系統，以偵測攻擊與未授權之連線，並識別資通系統之未授權使用

■ 資通系統監控-採用自動化監控工具(高)

- 資通系統應採用自動化工具監控進出之通信流量，並於發現不尋常或未授權之活動時，針對該事件進行分析
 - － 部署IPS、IDS、WAF、防火牆等具備自動化監控能力之網路安全防护產品以監控資通系統網路行為



5-7 系統與資訊完整性(4/4)

■ 軟體及資訊完整性-於伺服器端檢查(高中普)

- 使用者輸入資料合法性檢查應置放於應用系統伺服器端
 - － 輸入檢查應實作於伺服器端，不可依賴客戶端檢查(如JavaScript等)，以避免被惡意繞過

■ 軟體及資訊完整性-使用完整性驗證工具(高中)

- 使用完整性驗證工具，以偵測未授權變更特定軟體及資訊
 - － 這些工具通常會計算檔案或資料的雜湊值，並與已知的安全基準進行比較，以發現任何未經授權的修改。
- 發現違反完整性時，資通系統應實施機關指定之安全保護措施
 - － 如機關指定即時通報與告警、自動阻斷與隔離、保全日誌與復原等安全保護措施

■ 軟體及資訊完整性-定期檢查完整性(高)

- 應定期執行軟體與資訊完整性檢查
 - － 定期比對上線正式版本與版本控制系統之版本之內容差異，以發現潛藏之資安事件



資通系統防護基準-參考資源

- 以下文件可於國家資通安全研究院網站(www.nics.nat.gov.tw)自行下載

參考文件	用途說明
資通系統防護基準驗證實務	提供資通系統防護基準稽核驗證之參考
Web應用程式安全參考指引	提供機關於SSDLC流程中於開發階段實作相關安全控制措施之參考
安全軟體發展流程指引	提供機關推動SSDLC流程之參考
安全軟體測試參考指引	提供機關於SSDLC流程中於測試階段進行安全檢測活動之參考
安全軟體設計參考指引	提供機關於SSDLC流程中設計階段進行威脅識別與風險評估活動之參考
安全控制措施參考指引	提供包含技術面與管理面等全面性安全控制措施之參考
資通系統委外開發RFP範本	提供機關委外開發資通系統之RFP參考範本



5-8 媒體控管及可攜式設備(1/8)

■ 媒體控管-目的及工作

➤ 媒體包含

- 磁碟、磁帶、光碟及紙張

➤ 媒體控管的目的

- 避免儲存在其中的機敏資料外洩

➤ 媒體控管的工作

- 標示
- 使用紀錄
- 完整性檢查
- 實體存取保護
- 存放環境保護
- 運送保護
- 重用安全
- 銷毀與丟棄





5-8 媒體控管及可攜式設備(2/8)

■ 媒體控管-標示

➤ 媒體上應清楚標示

- 名稱與版本
- 機密等級
- 建立者
- 建立日期
- 保存期限
- 應銷毀日期





5-8 媒體控管及可攜式設備(3/8)

■ 媒體控管-重用

- **儲存媒體被轉移**：當儲存媒體被轉移到不同安全等級之資通系統使用時，應將其原來的資料安全地刪除，以避免資料殘存的問題
- **刪除檔案或格式化是不夠安全的**
只有刪除檔案指標，磁區內的資料有機會被復原
- **安全的資料刪除方式**
所有資料覆寫為「0或1」
 - US DoD作法：覆寫1→覆寫0→覆寫隨機0或1
 - US NSA作法：覆寫7次0→覆寫7次1



5-8 媒體控管及可攜式設備(4/8)

■ 媒體控管-安全丟棄

- 媒體要丟棄或銷毀前：應先安全的刪除資料或進行實體的破壞
- 儲存媒體破壞方法
 - 磁碟機：消磁設備或碎裂(6mm)
 - 磁帶：消磁設備
 - 光碟片：碎裂(6mm)





5-8 媒體控管及可攜式設備(5/8)

■ 可攜式設備-安全問題

- 公務家辦資料外洩
- 離職員工私自保留資料
- 普遍使用的USB硬碟成為病毒感染的主要途徑





5-8 媒體控管及可攜式設備(6/8)



■ 可攜式設備-存取控制與稽核

➤ 政策

- 應建立可攜式設備的使用限制與範圍

➤ 存取控制

- 可攜式設備對機關資通系統的存取，符合機關使用限制與範圍
- 關閉或避免觸發自動執行可攜式媒體中的程式，以避免病毒的傳染

➤ 稽核

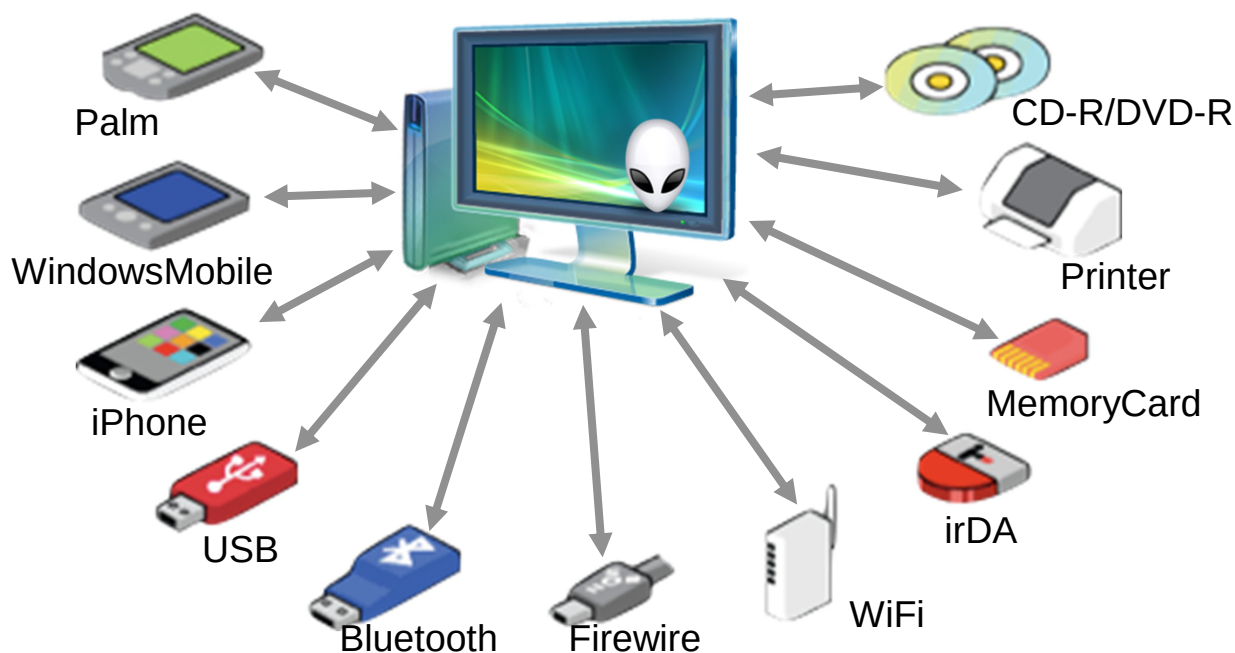
- 監視可攜式設備對資通系統的非授權存取



5-8 媒體控管及可攜式設備(7/8)

■ 可攜式設備-自動化安裝或啟用控管程式

- 安裝或啟用可攜式媒體控管程式，可「管制」、「偵測」及「記錄」各種可攜式媒體與設備的存取行為





5-8 媒體控管及可攜式設備(8/8)

■ 可攜式設備-稽核紀錄內容

➤ 稽核紀錄應包含下列欄位

- 事件發生時間(2017-11-12 11:34:12)
- 電腦名稱或IP位址(例如：WIN-LAB-05或192.168.10.150)
- 使用者名稱(RUBICON-SECURE\steven)
- 程序名稱與ID(Explorer.exe)
- 設備名稱(USB,CD/DVD,iPhone)
- 動作(Open,Write,Delete,CreateDir,etc...)
- 檔名(D:\autorun.inf)

NetworkAddr	UserName	CreationDate	Type	ProcessName	DeviceType	Action	Info	Name
ad.rubicon-secu	RUBICON-SECURE\Admini	2010-05-19 10:51:26	Success	C:\WINDOWS	DVD/CD-ROM	Device Access	Read	D:
ad.rubicon-secu	RUBICON-SECURE\Admini	2010-05-19 10:51:28	Success	C:\WINDOWS	DVD/CD-ROM	Open	DirList	D:\AutoPlay\
ad.rubicon-secu	RUBICON-SECURE\Admini	2010-05-19 10:51:29	Success	C:\WINDOWS	DVD/CD-ROM	Open	Read	D:\AutoPlay
ad.rubicon-secu	RUBICON-SECURE\Admini	2010-05-19 10:51:30	Success	C:\WINDOWS	DVD/CD-ROM	Open	DirList	D:\AutoPlay\Audio\
ad.rubicon-secu	RUBICON-SECURE\Admini	2010-05-19 10:51:30	Success	C:\WINDOWS	DVD/CD-ROM	Open	DirList	D:\AutoPlay\Buttons\
ad.rubicon-secu	RUBICON-SECURE\Admini	2010-05-19 10:51:30	Success	C:\WINDOWS	DVD/CD-ROM	Open	DirList	D:\AutoPlay\Docs\
ad.rubicon-secu	RUBICON-SECURE\Admini	2010-05-19 10:51:31	Success	C:\WINDOWS	DVD/CD-ROM	Open	DirList	D:\AutoPlay\Docs\Source\



第5單元-分組討論

1. 機關現行之資通系統日誌審查活動執行頻率與做法
2. 機關現行之資料備份執行方式，包含備份頻率、備份儲存媒體及是否進行異地備份等
3. 機關現行之系統備援機制或使用其他替代方案
4. 機關資通系統多因子鑑別技術適用對象、範圍及實作方式等，如採用之身分驗證因子種類等
5. 機關資通系統委外如何驗證系統安全需求已完成實作
6. 針對無法修復之資通系統安全漏洞，機關採用之補償與管理作為



第6單元

資通安全技術面應辦事項 - 資通安全之防護及偵測



第6單元學習目標

- 6-1 了解「防毒軟體」安全防護
- 6-2 了解「網路防火牆」安全防護
- 6-3 了解「應用程式防火牆」安全防護
- 6-4 了解「電子郵件過濾機制」安全防護
- 6-5 了解「IDS及IPS」安全防護
- 6-6 了解「APT」攻擊防禦措施
- 6-7 了解「SOC」管理機制
- 6-8 了解「GCB」組態基準
- 6-9 了解「VANS」弱點管理
- 6-10 了解「EDR」偵測及應變機制



資通安全之防護及偵測

制度面向	辦理項目	辦理細項	A級機關	B級機關	C級機關	D級機關
技術面	資通安全防護	防毒軟體	✓	✓	✓	✓
		網路防火牆	✓	✓	✓	✓
		電子郵件過濾機制	✓	✓		
		入侵偵測及防禦機制(IDS及IPS)	✓	✓	✓	
		應用程式防火牆	✓	✓		
		進階持續性威脅攻擊防禦措施(APT)	✓			
	資通安全監控管理機制(SOC)		✓	✓		
	政府組態基準(GCB)：適用公務機關		✓	✓		
	資通安全弱點管理(VANS)		✓	✓	✓	
	端點偵測及應變機制(EDR)		✓	✓		

備註：

1. 應用程式防火牆：具有對外服務之核心資通系統者：應備應用程式防火牆
2. 資通安全弱點管理：公務機關及特定非公務機關知悉資通安全弱點時，應適時修補或採行緩解措施；公務機關及關鍵基礎設施提供者依主管機關指定方式導入弱點管理作業，並持續維運



6-1 防毒軟體(1/2)

■ 用途

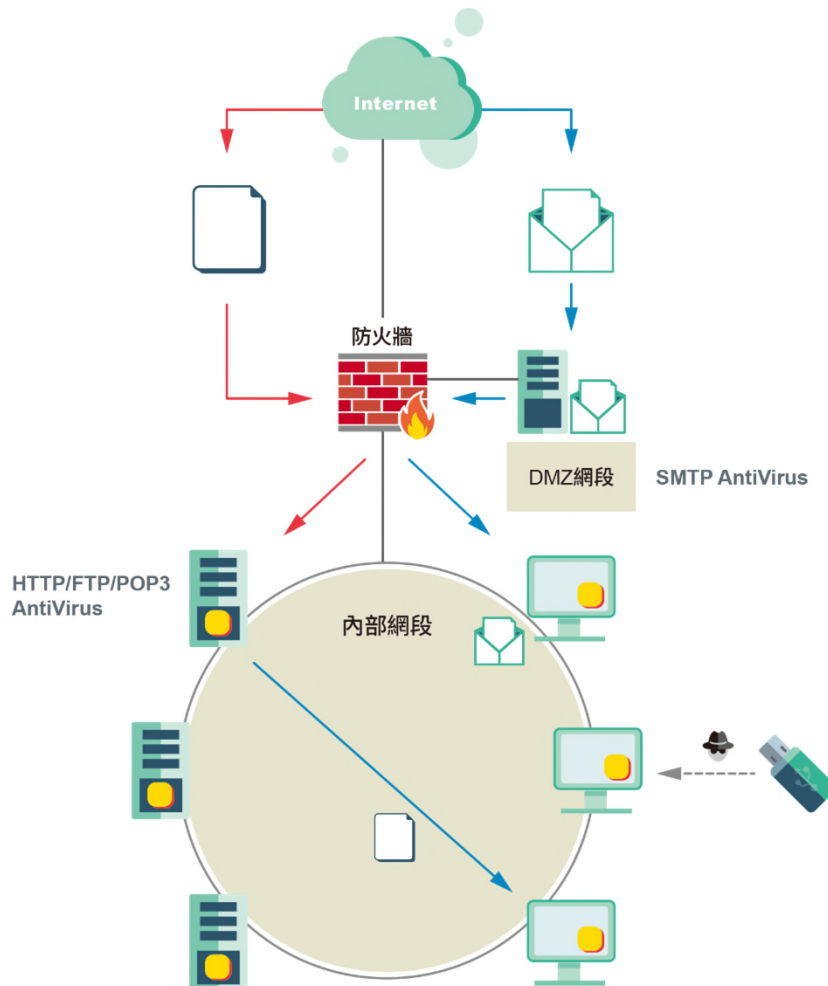
- 防止病毒、蠕蟲、間諜、後門及木馬等惡意程式入侵電腦軟體或系統

■ 惡意程式來源

- 電子郵件
- USB硬碟
- 網站瀏覽
- 即時通訊
- 檔案傳輸/分享

■ 部署方式

- 個人電腦與伺服器防毒
- 電子郵件防毒閘道
- 上網防毒閘道





6-1 防毒軟體(2/2)



■ 管理重點

- 應定期自動更新病毒碼
- 病毒感染的事件與趨勢應定期分析
- 避免未安裝防毒軟體的電腦上線(配合NAC設備)
- 防火牆控管未經防毒閘道過濾的連線行為
- 「個人電腦與伺服器防毒系統」與「防毒閘道系統」可採用不同廠牌

■ 選購考量

- 病毒偵測的精準度
- 對電腦效能的影響
- 是否提供中央控管機制



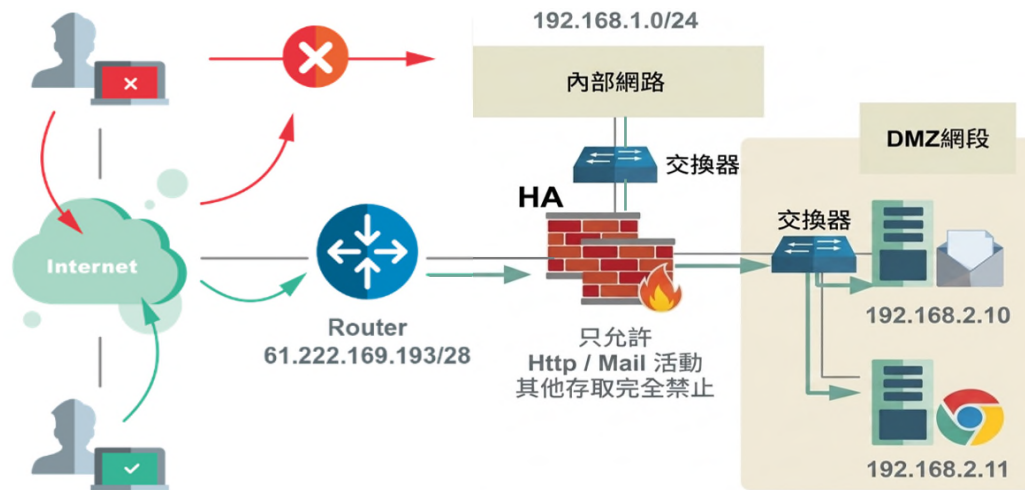
6-2 網路防火牆(1/3)

■ 網路防火牆：

- 是一台專屬的硬體或是架設在一般硬體上的軟體，依照特定的規則允許或限制傳輸的資料通過網路。

■ 用途

- 區隔不同安全等級網段 (如外部網路、內部網路及DMZ)
- 過濾資料封包，避免未經授權存取內部網路資源
- 提供稽核與控制存取網路資源

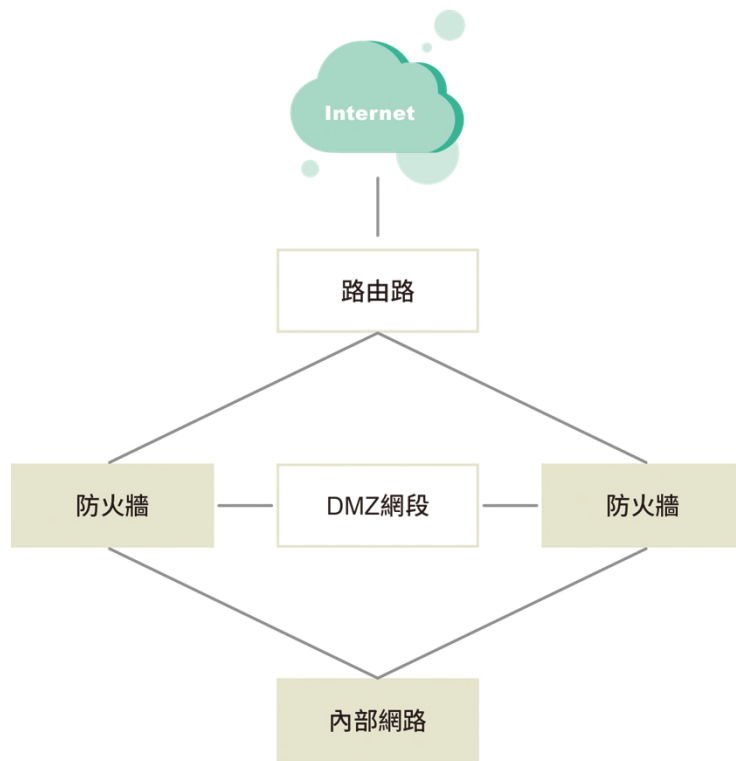




6-2 網路防火牆(2/3)

■ 部署方式

- 考量資安需求，妥善劃分IP網段與虛擬區域網路
- 建置2台防火牆並設定成高可靠度(High Availability)運作模式，當主要防火牆出現問題時，次要防火牆即接手主要防火牆的工作





6-2 網路防火牆(3/3)



■ 管理重點

- 防火牆存取規則的變更應建立管理程序(變更申請、核准及記錄)
- 防火牆存取紀錄應即時匯出存檔，並保留足夠的時間
- 定期產出異常存取統計分析報表，進行異常處理
- 防火牆存取控管規則應定期盤查(A級機關每年1次，B級機關2年1次)

■ 選購考量

- 防火牆本身的安全性
- 可區隔的網路區段數應符合機關需求
- 可支援的傳輸頻寬大小符合機關需求
- 具備第七層(應用層)防護能力



6-3 應用程式防火牆(1/4)

■ 應用程式防火牆：

- 是針對應用層封包進行管制的防火牆機制，特別是針對網站應用的防護，常見為網站應用程式防火牆 (Web Application Firewall, WAF)。
- 具有對外服務之核心資通系統者，應備應用程式防火牆





6-3 應用程式防火牆(2/4)



■ 網站應用程式防火牆(WAF)用途：

- 偵測與防禦針對網站應用程式之攻擊行為(例如：SQL Injection與Cross-Site Scripting等)

■ 偵測與過濾技術

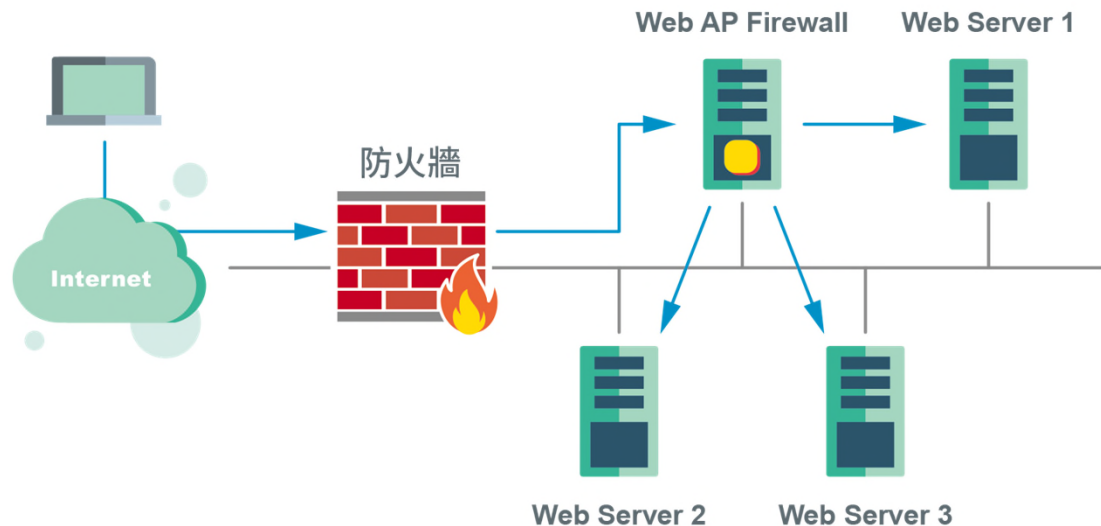
- 白名單:只有列在白名單的網頁與參數才能通過，其他一律拒絕。理論上最安全且可防範未知攻擊，但實務上無法學習到100%的白名單
- 黑名單:列在黑名單的網頁與參數一律拒絕
- 攻擊特徵判斷:目前較常用的作法，但會有誤判與漏判的問題



6-3 應用程式防火牆(3/4)

■ 類型與部署方式

➤ 硬體式



➤ 軟體式





6-3 應用程式防火牆(4/4)



■ 管理重點

- 存取規則的變更應建立管理程序(變更申請、核准及記錄)
- 異常的網站應用程式攻擊事件應立即匯出，並保留足夠的時間
- 異常的網站應用程式攻擊事件應定期分析，並進行異常的處理

■ 選購考量

- 處理效能應符合機關網站流量需求
- 中文URL及傳輸內容的判斷能力
- HTTPS的加密連線可先在網站應用程式防火牆解密過濾後，再轉到後端真正的網站(IDS/IPS無法判斷HTTPS連線)



6-4 電子郵件過濾機制(1/3)



■ 電子郵件過濾機制：

- 指具有郵件伺服器者，應備電子郵件過濾機制
- 一般指具垃圾郵件過濾之系統

■ 用途

- 過濾垃圾與廣告郵件
- 避免電子郵件社交工程攻擊

■ 垃圾郵件判斷技術

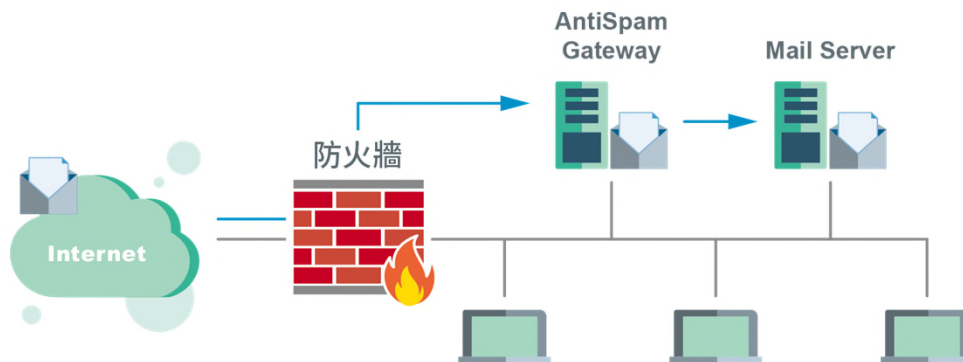
- 連線模式
- 關鍵字比對
- 內容過濾條件
- 外部資料庫比對
- 貝氏演算法
- 圖片辨識技術



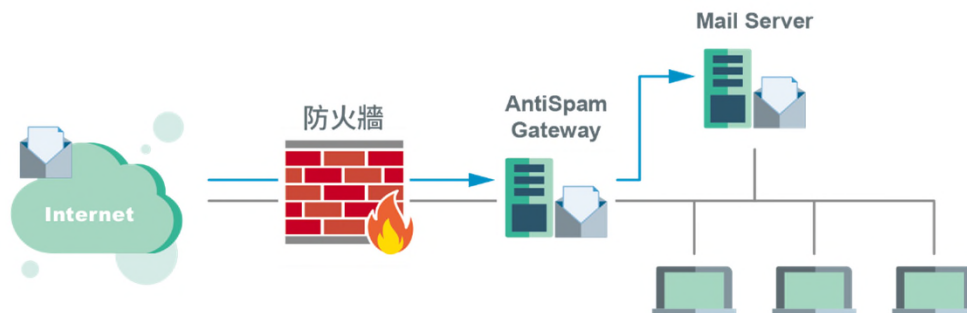
6-4 電子郵件過濾機制(2/3)

■ 部署方式

- 閘道模式(Mail Relay)
 - 不影響其他網路流量
 - 設備故障時信件無法進出
 - 安全性高(Fail Close)



- Bridge模式(目前較少見)
 - 會影響其他網路流量
 - 設備故障時會自動Bypass流量
 - 安全性低(Fail Open)





6-4 電子郵件過濾機制(3/3)



■ 管理重點

- 應定期自動更新垃圾郵件辨識特徵碼
- 電子郵件過濾規則的變更應建立管理程序(變更申請、核准及記錄)

■ 選購考量

- 垃圾郵件判斷的精準度
- 處理效能可符合機關需求
- 對於中文信件或多國語言的支援能力
- 全文檢索支援中文的能力與郵件附件的檢索能力
- 圖片廣告信件的支援能力
- 防禦商業電子郵件詐騙(BEC)及AI生成釣魚信件的分析能力



6-5 IDS及IPS(1/4)

■ 入侵偵測及防禦系統(IDS及IPS)

➤ 用途

- 識別網路的異常行為與攻擊行為(注意：加密連線的內容無法識別)，特定之攻擊行為可以立即阻擋

➤ 技術類型

- 特徵碼比對
 - 比對攻擊特徵碼、判斷較精準
 - 只能偵測已知攻擊
- 異常行為模式分析
 - 統計分析比對出異常行為
 - 能偵測未知類型攻擊
 - 較易誤判
- 狀態協定分析
 - 事先定義完整協定行為
 - 較為精準，可偵測未知類型攻擊
 - 耗費運算資源，影響系統效能



6-5 IDS與IPS(2/4)

■ 入侵偵測與防禦系統

➤ 反應方式

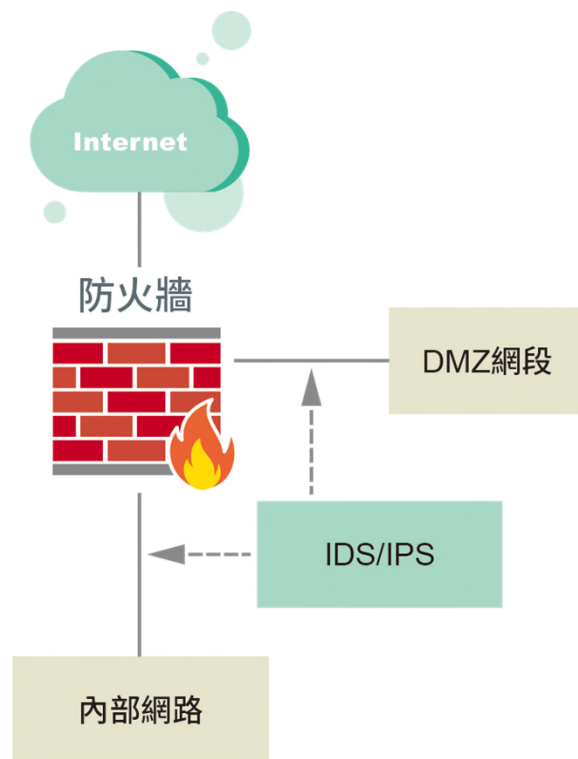
- 被動方式：只將異常事件記錄下來，供日後稽核分析使用
- 主動方式：立即將攻擊事件或攻擊來源進行封鎖

➤ 部署方式

- 監聽模式：不影響網路部署，但防禦效果較差
- Bridge模式：防禦能力較強

➤ 部署位置

- 建議為DMZ區與內部網路進出口





6-5 IDS與IPS(3/4)

■ IDS與IPS的比較

特性	IDS	IPS
監控方式	被動	主動
反應能力	僅報告	自動防禦
部署位置	網路邊緣或主機	內聯於網路流量中
誤報風險	較低	較高
即時防護	無	有



6-5 IDS與IPS(4/4)

■ 選購考量

- 精準之特徵碼資料庫
 - 具有針對軟體弱點防護能力而非僅有針對特定攻擊撰寫之特徵碼
 - 預設特徵碼不會產生許多誤判與漏判
- 效能經過實測
- 針對DoS/DDoS攻擊能分辨合法封包與攻擊封包之差異
- 完整且彈性之報表系統、中央管理機制及對IM與P2P之管理能力



6-6 APT攻擊防禦措施(1/2)

■ 進階持續性威脅(Advanced Persistent Threat, APT)攻擊防禦措施

➤ 是一種針對特定組織的複雜且多方位的網路攻擊，主要的特色是：



■ 防禦措施：

- 透過日誌、監測機制、資通安全威脅偵測管理等方式
- 透過跨機關的資安聯防機制、情資的交換機制等，將有助於安全防禦策略及戰略的佈署
- 透過備份管理等機制，於此類攻擊後，進行快速的復原，減少系統功能的減損與中斷



6-6 APT攻擊防禦措施(2/2)

■ 用途

- 增強組織抵禦APT攻擊的整體能力
- 降低APT攻擊造成的風險及損害
- 建立完善的APT防禦體系

■ 部署方式

- 多層次安全防護：結合網路、端點及應用層面的安全控制措施
- 持續的威脅情報收集及分析：監控APT攻擊趨勢及手法
- 完善的事件應變機制：建立快速檢測、遏制及修復的程序
- 持續監控及適應性調整：根據威脅變化不斷優化防禦策略

■ 管理重點

- 確保多層次安全防護的全面性及協同性
- 持續更新及分析最新的威脅情報
- 確保事件應變流程的高效性及可靠性
- 建立靈活的監控及調整機制



6-7 SOC管理機制(1/3)

■ 資通安全監控管理機制(SOC)

- 資通安全監控管理機制(Security Operation Center, SOC)提供資通設備紀錄與資訊服務或應用程式紀錄等資安監控、事件處理、資安威脅預警等服務，適用於A級機關及B級機關
- SOC監控範圍包括：
 - 端點偵測及應變機制(EDR)
 - 資通安全防護：防毒軟體
 - 資通安全防護：網路防火牆
 - 資通安全防護：電子郵件過濾機制
 - 資通安全防護：入侵偵測及防禦機制(IDS/IPS)
 - 資通安全防護：應用程式防火牆
 - 資通安全防護：進階持續性威脅攻擊防禦措施(APT)
 - 目錄服務系統
 - 核心資通系統之日誌紀錄及資通設備紀錄
- 其他監控範圍：建議可依機關實務需求納入監控



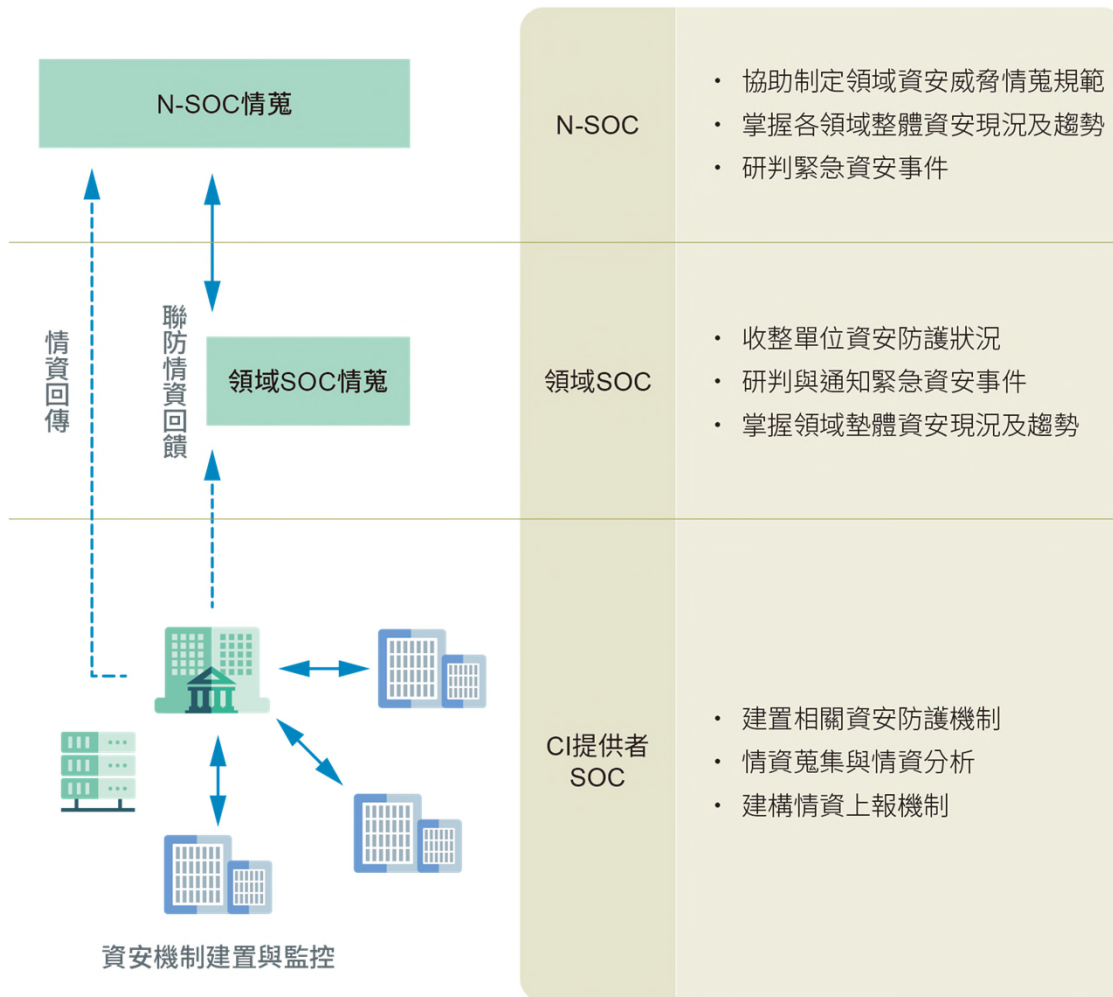
6-7 SOC管理機制(2/3)

- SOC可以協助機關提升資安監控之有效性，包含
 - 7x24全天候監控服務
 - 即時告警
 - 追蹤分析與應變處理
 - 定期提供網路威脅分析統計報表等
- 監控與網路同步運作：納管多樣資安設備使整體分析更全面
- 搭配全球預警、威脅情資等服務及專屬事件追蹤平台，協助機關可即時掌握最新網路風險狀態及安全資訊



6-7 SOC管理機制(3/3)

■ 資通安全監控管理聯防機制 - 以CI提供者SOC為例





6-8 GCB組態基準(1/6)



■ 組態管理(1/2)

➤ 組態

- 為IT系統邏輯模型，包含：服務、軟體、硬體、設定、文件及IT人員等組態項目(Configuration Item, 簡稱CI)
- 組態項目間是有互動與關聯的

➤ 組態管理

- 識別、控制、維護及檢查現有IT系統中所有的組態元件及其之間的關聯性

➤ 組態管理資料庫(Configuration Management Database, CMDB)

- 儲存最新IT系統所有組態項目及其關聯性的資料庫
- 其儲存形式可以是文件、檔案或關聯式資料庫



6-8 GCB組態基準(2/6)

■ 組態管理(2/2)

➤ 組態管理的目的

- IT資產管理
- 提供IT服務管理作業中所需的精確資訊
- 降低因變更對系統造成的各類負面影響

➤ 透過「變更管理」維護IT系統的組態現況

- 在「變更管理」的流程中應加入「變更組態」的動作，以隨時更新組態資料庫



6-8 GCB組態基準(3/6)

■ 組態變更管理(1/2)

➤ 變更管理項目

- 記錄變更內容與過程
- 評估變更的衝擊、成本、效益、資源需求及風險
- 取得授權與核准
- 管理與協調變更的實作
- 變更實作監督與回報

➤ 變更組態管理資料庫(CMDB)以反映變更後現況



6-8 GCB組態基準(4/6)

■ 組態變更管理(2/2)

- 當IT系統之組態變更時，應考量對系統營運的安全影響
 - 可用性影響
- 變更前應釐清組態項目的關聯性
 - 安全組態影響
 - 存取控制影響





6-8 GCB組態基準(5/6)

■ 政府組態基準導入

- **政府組態基準(Government Configuration Baseline · GCB)：**
目的在於規範資通訊設備(如：個人電腦、伺服器主機及網通設備等)之一致性安全設定(如：密碼長度、更新期限等)，提升政府機關資通訊設備之資安防護
- **政策要求：**從中央部會推動至所屬機關及地方政府
- **部署範圍：**從終端設備擴及至伺服器及資通安全設備
- **GCB導入：**是A級與B級公務機關必須辦理事項

1

發展一致性安全組態設定

2

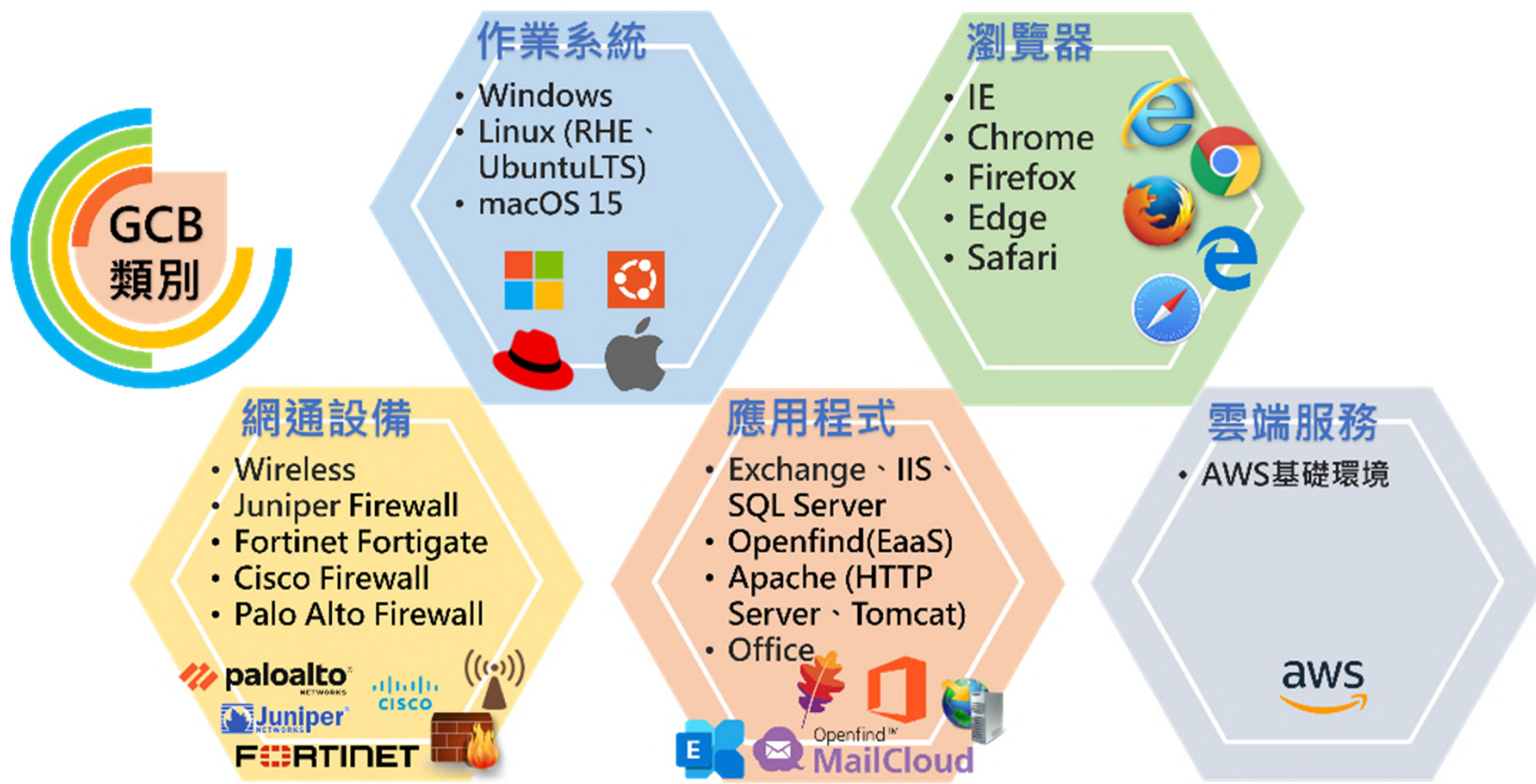
提升政府機關資通訊設備之資安防護





6-8 GCB組態基準(6/6)

■ 政府組態基準之類別及項目





6-9 VANS弱點管理(1/4)

■ 資通安全弱點管理 – 目的及適用對象

➤ 目的：

指結合資訊資產管理與弱點管理，掌握整體風險情勢，並協助機關落實本法有關資產盤點及風險評估應辦事項之作業

➤ 適用對象：

A級、B級及C級機關

- **公務機關及特定非公務機關**：知悉資通安全弱點時，應適時修補或採行緩解措施
- **公務機關及關鍵基礎設施提供者**：依主管機關指定方式導入弱點管理作業，並持續維運。



6-9 VANS弱點管理(2/4)

■ 資通安全弱點管理 – VANS

- 資通安全弱點通報系統(Vulnerability Alert and Notification System, VANS)：結合資訊資產管理與弱點管理，掌握整體風險情勢，並降低重大弱點爆發時可能造成之損害
 - 定期蒐集資通系統主機與電腦所使用之資訊資產項目及版本，建立資訊資產清冊，以達到降低風險與管控成本等目標
 - 將資訊資產清冊與弱點資料庫比對，以掌握所使用資訊資產是否存在已公開揭露之弱點資訊





6-9 VANS弱點管理(3/4)

■ VANS-提供服務

- VANS可協助機關落實資通安全管理法之**資產盤點與風險評估**應辦事項，並提供以下服務
 - 透過VANS持續維護資訊資產盤點資料
 - 針對機關登錄的資訊資產項目進行弱點比對，以協助進行系統化風險評估
 - 依照機關訂定之風險值門檻，即時提醒資訊資產風險情形，並進行弱點評估與修補作業
 - 提供微軟安全性更新檢測報告解析功能，協助機關以自動化方式檢視安全性更新落實程度





6-9 VANS弱點管理(4/4)

■ VANS-資訊資產涵蓋範圍





6-10 EDR偵測及應變機制

■ 端點偵測及回應機制

- **A級及B級機關**：應完成端點偵測及應變機制導入作業，並持續維運及依主管機關指定之方式提交偵測資料
- **用途**
 - 偵測與阻擋威脅
 - 確保端點設備安全
- **技術類型**
 - 行為分析、規則比對、黑白名單等技術
- **選購考量**
 - 偵測威脅的精準度
 - 可與防毒軟體整合
 - 系統呈現的攻擊事件資訊詳盡且易於判讀



第6單元-分組討論

1. 機關如何確保所有端點裝置(含個人電腦與伺服器)的防毒軟體都能定期自動更新病毒碼，以及如何透過技術或管理手段，避免未安裝或未正常運作防毒軟體的電腦上線，請分享管理作為及實務經驗。
2. 機關針對網路防火牆的存取規則之變更管理程序 (例如變更申請、核准及記錄流程)，以及定期盤查存取控管規則，請分享管理作為及實務經驗。
3. 機關是否有部署網站應用程式防火牆(WAF)？若有，請分享如何部署 (硬體式或軟體式) 以及相關的管理 (例如偵測與過濾技術的選擇、存取規則變更程序、異常事件的處理流程) 的具體作法。若無，目前如何防護網站應用程式攻擊？
4. 機關使用何種電子郵件過濾機制？其對於過濾垃圾及惡意郵件 (含社交工程信件) 的成效如何？請分享電子郵件過濾規則的管理方式(例如規則變更程序)，以及如何定期自動更新垃圾郵件辨識特徵碼。
5. 機關是否有部署入侵偵測系統(IDS)或入侵防禦系統(IPS)？請分享部署位置 (例如DMZ區或內部網路進出口) 以及如何處理IDS/IPS產生的告警或阻擋事件 (是被動記錄分析，還是主動封鎖來源)。
6. 機關是否有導入SOC管理機制 (自行建置或委外服務)？請分享SOC如何協助監控不同資安設備 (如防火牆、防毒系統、WAF、IDS/IPS、EDR等) 的日誌與告警，以及如何處理SOC發出的資安事件通知。
7. 機關在導入GCB時，面臨哪些挑戰？請分享如何針對不同類型的資通訊設備 (例如Windows作業系統、Office應用程式、瀏覽器、網路設備等) 落實GCB設定，並確保符合規範的具體作法。